

FACULTY OF COMPUTING AND INFORMATICS

BACHELOR OF DEGREE IN COMPUTER SCIENCE

CCS6224 — Network Security

ASSIGNMENT: Enterprise Network Security Audit & Hardening Plan

GROUP 5

Student ID	Student Name
253UC256V0	Muhammad Nabil Haziq Bin Ahmad Jefry
253UC256X4	Viandra Lika Nur Prastya
253UC256QP	Lim Guan Yee
242UC244Q1	Muhammad Aref bin Mohd Hasni

Table of Content

1. Executive Summary.....	2
2. Scope and Methodology.....	4
2.1 Scope of Assessment.....	4
2.2 Methodology.....	5
3. Threat Assessment Findings.....	6
3.1 Introduction.....	6
3.2 Passive Attacks.....	6
3.2.1 Introduction.....	6
3.2.2 Relevance to SecureFlow Sdn. Bhd.....	6
3.2.3 Threat Categories.....	7
3.2.4 Threat Explanation.....	7
3.3 Active Attacks.....	8
3.3.1 Introduction.....	8
3.3.2 Relevance to SecureFlow Sdn. Bhd.....	8
3.3.3 Threat Categories.....	8
3.3.4 Threat Explanation.....	9
3.4 Layer 2 Attacks.....	10
3.4.1 Introduction.....	10
3.4.2 Relevance to SecureFlow Sdn. Bhd.....	10
3.4.3 Threat Categories.....	10
3.4.4 Threat Explanation.....	11
3.5 Wireless Network Threats.....	12
3.5.1 Introduction.....	12
3.5.2 Relevance to SecureFlow Sdn. Bhd.....	12
3.5.3 Threat Categories.....	12
3.5.4 Threat Explanation.....	13
3.6 Application-Layer Threats.....	14
3.6.1 Introduction.....	14
3.6.2 Relevance to SecureFlow Sdn. Bhd.....	14
3.6.3 Threat Categories.....	14
3.6.4 Threat Explanation.....	15
3.7 Vulnerability Assessment Matrix.....	17
3.8 Closing paragraph.....	18
4. Network Architecture and Hardening Evidence.....	19
4.1 Network Topology.....	19
4.2 Internet Zone.....	20
4.3 DMZ Zone.....	23
4.4 Internal LAN Zone.....	26
4.5 Guest Wireless Zone.....	33
4.6 Branch Office Zone.....	35
4.7 Cross-Zone Security and High Availability.....	39
4.8 Packet Tracer Limitations and Design Adaptations.....	43
5. Security Protocol Evaluation.....	44

5.1 TLS 1.2 vs TLS 1.3 Analysis.....	44
5.1.1 Introduction.....	44
5.1.2 Cryptographic Improvements in TLS 1.3.....	45
5.1.3 Downgrade Attack Considerations.....	46
5.1.4 Recommendation.....	46
5.2 Email Security Evaluation: SPF, DKIM and DMARC.....	47
5.2.1 Introduction.....	47
5.2.2 Sender Policy Framework (SPF).....	47
5.2.3 DomainKeys Identified Mail (DKIM).....	48
5.2.4 Domain-based Message Authentication, Reporting and Conformance (DMARC)	48
5.2.5 How SPF, DKIM and DMARC Work Together.....	48
5.2.6 Remaining Limitations.....	49
5.2.7 Recommendation.....	49
5.3 IPsec VPN vs TLS VPN Comparison.....	50
5.3.1 Introduction.....	50
5.3.2 Comparative Analysis.....	51
5.3.3 Suitability for SecureFlow.....	52
5.3.4 Performance Overhead.....	53
5.3.5 Deployment Complexity.....	53
5.3.6 Security Assurance.....	53
5.3.7 Recommendation.....	54
6. Consolidate Recommendation.....	55
6.1 Security Improvement Roadmap.....	57
7. Conclusion.....	58
8. References.....	60

1. Executive Summary

SecureFlow Sdn. Bhd. is an early-stage fintech company that's in the process of integrating sophisticated financial services processes with advanced technologies to help customers conveniently manage their finances. In light of the increasing number of cyber attacks targeting financial institutions, financial services organizations face a variety of security risks. These risks threaten your organization's network infrastructure, customer financial data and continuing business operations. This assessment was completed to identify the potential risks to SecureFlow's network environment and to recommend security measures that could be used to improve SecureFlow's overall security posture.

During this assessment, various network threats were found to exist that could adversely impact SecureFlow's confidentiality, integrity and availability of its systems and customer financial data as well as number of technology-related threats including eavesdropping, man in-the-middle attacks, denial-of-service (DoS) attacks, ARP Spoofing, phishing-based malware, access via unauthorized or rogue access points and email spoofing. The assessment identified three primary areas of SecureFlow's wireless network, remote access services to organization's internal network for external users and all of SecureFlow's public-facing systems that require increasing levels of security.

The assessment also recognizes the need for the following recommendations to mitigate these risks: Implement VLAN segmentation; strengthening the firewall access control rules; enable secure communication via a VPN; harden all network devices; improve the overall security of SecureFlow's wireless networks. Additionally, the report provides a brief overview of current security standards/protocols (TLS 1.3; IPsec VPN; SPF; DKIM; DMARC) to assist with ensuring SecureFlow's communication and email communications are adequately protected.

To summarize, SecureFlow is using a currently functioning operational networking system; however, additional levels of security should be implemented in order to protect from modern day cyber attacks. The implementation of recommended controls/security best practices outlined in this report will help SecureFlow improve network security, decrease exposure to risk, and comply with applicable regulations/standards (PDPA, PCI DSS).

2. Scope and Methodology

2.1 Scope of Assessment

This assessment focuses on the network infrastructure and security environment of SecureFlow Sdn. Bhd., which is a fintech company located in Cyberjaya, Malaysia. The assessment mainly focuses on several important parts of the company's network, including the internal Local Area Network (LAN), wireless network, DMZ servers, VPN connectivity, and network device configurations. The purpose of this assessment is to identify possible security threats and vulnerabilities that may affect the confidentiality, integrity, and availability of the organisation's systems and customer financial data.

The assessment includes:

- Network segmentation and VLAN security
- Wireless network security for staff and guest users
- Firewall and Access Control List (ACL) configurations
- VPN communication security
- Switch and router hardening
- Security protocol analysis for TLS, IPsec, SPF, DKIM, and DMARC
- Intrusion Detection System (IDS) and Intrusion Prevention System (IPS)

This assessment was conducted using a simulated network environment based on the SecureFlow scenario provided in the assignment brief. Cisco Packet Tracer was used to simulate the enterprise network and security configurations. No real enterprise systems or live company networks were tested during this assessment.

2.2 Methodology

This assessment was carried out using a structured approach to identify, analyse, and evaluate network security threats that may affect SecureFlow Sdn. Bhd. The STRIDE threat modelling framework was chosen because it provides a simple and organised way to classify cybersecurity threats in a network environment. STRIDE consists of six categories, which are Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege.

Several security concepts learned throughout the course were applied to analyse the SecureFlow network environment, it includes network segmentation, wireless security, firewall protection, VPN security and access control mechanisms. Potential threats that identify based on the company network architecture, business operations and security requirements. Each identifying threat was evaluated using the Vulnerability Assessment Matrix that considered the likelihood of happening, potential impact on the organization, affected OSI layer and recommended security controls.

3. Threat Assessment Findings

3.1 Introduction

SecureFlow Sdn. Bhd. operates in the financial technology industry, which makes the company more exposed to cybersecurity threats that may target the sensitive customer information, online services, and internal systems. Since the company relies heavily on internet communication, wireless connectivity, VPN access, and customer-facing services, different types of cyberattacks may affect the confidentiality, integrity, and availability of the network infrastructure and company data.

The threat modelling framework of STRIDE has been used to provide an analysis and identification of threat types. As a result, cybersecurity threats have been categorized and identified into six categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. This allows for an easier identification of possible threats to the SecureFlow network environment, as well as the implementation of appropriate security controls to mitigate the corresponding risk posed by the identified threats.

3.2 Passive Attacks

3.2.1 Introduction

Cybersecurity threats classified as passive attacks use no methods to change transmitted data, but involve monitoring, intercepting or collecting data from an organization's network communications. Usually an organization would find it difficult to detect any evidence of passive attack because a passive attack does not impact their operational network functions or alter their physical resources. Examples of passive attacks are eavesdropping and traffic analysis whereby an attacker would be able to monitor the communication patterns of an organization to obtain sensitive data. In addition, there is an increased threat level posed by passive attacks within a fintech company such as SecureFlow Sdn. Bhd due to the nature of the attack being able to compromise the confidentiality of customer financial information and/or internal business communications.

3.2.2 Relevance to SecureFlow Sdn. Bhd

Because SecureFlow Sdn. Bhd. transmits sensitive financial information, customer records, and other types of business data using internal networks and Virtual Private Network (VPN) connections, passive attacks could be an issue for the company as attackers may be able to gather information without being detected. Therefore, using secure communication channels to provide these fintech services requires protection against passive attacks in order to protect the confidentiality of the data and maintain the trust of our customers.

3.2.3 Threat Categories

Threat Name	Category	Likelihood (H/M/L)	Impact (H/M/L)	Affected Layer (OSI)	Recommended Control
Eavesdropping	Passive Attack	Medium	High	Layer 2	VPN encryption and secure communication protocols
Traffic Analysis	Passive Attack	Medium	Medium	Layer 2	Network encryption and traffic monitoring

3.2.4 Threat Explanation

Eavesdropping

An attacker can capture the communication of a network in order to steal sensitive information, including usernames, passwords, and financial data for a customer. The threat to the Information Disclosure category in STRIDE exists as the attacker is trying to get access to confidential information without changing the communication. The likelihood is rated medium based on the fact that SecureFlow relies on wireless communications and remote access services, where if encryption is weak or misconfigured, this would pose significant vulnerability to an eavesdropping attack. The impact of eavesdropping attacks on customer trust and the company's reputation as a result of leaking sensitive financial information is rated high.

Traffic Analysis

Attackers may also gather data from system events and settings without directly interacting with those systems through traffic analysis, which monitors network communications for behavioural patterns. Attackers regularly use this method of attack and are part of the STRIDE Information Disclosure attack category; it could lead to information collection from both traffic flow and communication behaviour. The likelihood of an attack by a third party is rated medium since SecureFlow regularly transmits information between secured devices, the operational and financial data is secure through SSL encryption. The impact of such an attack is rated medium since SSL encryption does provide some level of security, however, an attacker can still gather useful information from traffic patterns and network activity even if the data is encrypted.

3.3 Active Attacks

3.3.1 Introduction

Active attacks are cybersecurity threats that involve modification, disruption or manipulation of network communications and system resources. It does not like passive attacks, active attacks directly interfere with normal network operations and may compromise the confidentiality, integrity or availability of information. The threats Man-in-the-Middle (MitM), Denial of Service (DoS) and replay attacks can cause service disruptions, unauthorized access, data manipulation and financial loss. These causes can make organisations significant concerns operating in the financial technology sector.

3.3.2 Relevance to SecureFlow Sdn. Bhd

SecureFlow "Sdn Bhd" has many online services offered to customers, therefore is very susceptible to active attacks, especially given that their daily operations depend upon; VPN connections, Wireless communications (802.11), and internal networks. Active attackers will use these modes of communications in order to impersonate a company's customer or otherwise disrupt business operations by intercepting messages between customers and the company; they may also gain access to sensitive data, by unauthorized or fraudulent means. The company must establish reasonable security controls to minimize the possibility or risk of active attacks and preserve a network's confidentiality, integrity and availability ("CIA").

3.3.3 Threat Categories

Threat Name	Category	Likelihood (H/M/L)	Impact (H/M/L)	Affected Layer (OSI)	Recommended Control
Man-in-the-Middle (MitM)	Active Attack	High	High	Layer 3	TLS encryption and certificate validation
Denial of Service (DoS)	Active Attack	High	High	Layer 3/4	Firewall filtering and IDS/IPS
Replay Attack	Active Attack	Medium	High	Layer 3/4	Session tokens, timestamps and anti-replay mechanisms

3.3.4 Threat Explanation

Denial-of-Service (DOS)

A Denial-of-Service (DOS) attack attempts to make a server/service unavailable to legitimate users by overwhelming it with requests until it cannot respond anymore. Denial-of-Service attacks are classified under the Denial of Service threat category in the STRIDE framework because they directly affect the availability of a system. The likelihood of this happening has a high probability since many fintechs experience these types of attacks to their online services and customer-facing systems. The potential for an attack to cause a business disruption, decrease their customer's trust in them as a business, along with an outright loss in revenue will have a very high impact if the attack is successful.

Man-in-the-Middle (MITM)

When one person communicates with two other people, an intruder can intercept their messages without the intruder being detected, just like when one person types on his computer and the other two see the messages at the same time. This type of attack falls under the Spoofing and Tampering categories of the STRIDE framework, as an intruder could appear as a trusted user of a device but could change what is transmitted. Due to the dependance of SecureFlow on VPN, web applications and wireless communication, the threat of MITM attacks is significant. There is a high potential for an intruder to gain access to credentials, alter transactions and/or gain unauthorized access to company systems.

Replay Attack

A replay attack shows up when an attacker captures legitimate network communication and retransmits them after some time to gain unauthorized access or perform fraudulent actions. This threat is related to Spoofing and Repudiation categories in the STRIDE framework because attackers reuse the valid authentication data to pretend as legitimate users. The likelihood is medium because SecureFlow implements secure authentication mechanisms but the weakness in session management or authentication protocols still create opportunities for replay attack. The impact is high because successful attacks allow unauthorized access to the system and compromise sensitive financial information.

3.4 Layer 2 Attacks

3.4.1 Introduction

Layer 2 attacks are cybersecurity threats that target the Data Link Layer (layer 2) on the OSI model, these attacks exploit weakness in network switching protocols, MAC address management and VLAN configurations to gain unauthorised access to network resources or intercept the network traffic. Layer 2 threat includes ARP Spoofing, VLAN hopping and MAC flooding, and these attacks occur within the local network environment so it can be difficult to detect and may compromise the confidentiality, integrity and availability of the network communications.

3.4.2 Relevance to SecureFlow Sdn. Bhd

Layer 2 attacks are cybersecurity threats that target the Data Link Layer (layer 2) on the OSI model, these attacks exploit weakness in network switching protocols, MAC address management and VLAN configurations to gain unauthorised access to network resources or intercept the network traffic. Layer 2 threat includes ARP Spoofing, VLAN hopping and MAC flooding, and these attacks occur within the local network environment so it can be difficult to detect and may compromise the confidentiality, integrity and availability of the network communications or VLAN implementations. Securing the Layer 2 infrastructure is essential to maintain the CIA of the network environment. .

3.4.3 Threat Categories

Threat Name	Category	Likelihood (H/M/L)	Impact (H/M/L)	Affected Layer (OSI)	Recommended Control
ARP Spoofing	Layer 2 Attack	High	High	Layer 2	Dynamic ARP Inspection (DAI)
VLAN Hopping	Layer 2 Attack	Medium	High	Layer 2	Proper VLAN configuration and unused port shutdown
MAC Flooding	Layer 2 Attack	Medium	Medium	Layer 2 (Data Link)	Port Security and MAC address limiting

3.4.4 Threat Explanation

ARP Spoofing

When ARP Spoofing occurs, attackers will send forged ARP packets over the local area network in order to create a relationship between their MAC address and the IP address of some other device on that local area network. ARP Spoofing falls under two of the threat categories in STRIDE: Impersonation and Tampering, since the attackers wish to impersonate a valid device as well as manipulate network communications. The threat's probability is considered high as attackers may be able to intercept sensitive communications, conduct MITM attacks, or cause disruptions in the normal operation of the internal data network.

VLAN Hopping

VLAN Hopping occurs when attackers circumvent VLAN segmentation and connect to compromised VLANs to access information or resources that belong to other VLANs. This type of attack is associated with the Elevation of Privilege vulnerability according to the STRIDE methodology, as attackers try to gain unauthorized access to another VLAN. The likelihood of VLAN Hop occurring is rated as moderate because it is likely that SecureFlow has implemented effective VLAN segmentation; however, VLAN(s) may still be vulnerable because of poor system configuration on VLAN trunks. The impact of VLAN Hop will be high if attackers are able to connect to sensitive departments (e.g., financial, payroll, human resource departments) that contain confidential data.

MAC Flooding

MAC flooding is a Layer 2 attack where an attacker overwhelms a large number of fake MAC addresses into a network switch. It lets the switch MAC address table become full, causing the switch to behave like a hub and broadcast network traffic to all connected devices. This threat is the category in the STRIDE framework Denial of Service and Information Disclosure because it can disrupt normal network operation and expose sensitive network traffic to the attackers. The likelihood is medium because the attack needs access to the local network and special tools. The impact is medium because successful MAC flooding allows attackers to intercept network traffic, reduce network performance and compromise the confidentiality of sensitive information. Recommended controls are implementing Port Security and limiting the number of MAC addresses allowed on the switch port.

3.5 Wireless Network Threats

3.5.1 Introduction

Wireless network threats is a cybersecurity attack that targets the wireless communication systems and network access points. These threats exploit weaknesses in wireless protocols, authentication mechanisms and using user trust to gain unauthorized access to network resources or intercept sensitive information. Threat includes rogue access point, evil twin attack and WPA2 cracking, because organisations rely on wireless connectivity for daily operations securing wireless networks is important to protect the CIA information system.

3.5.2 Relevance to SecureFlow Sdn. Bhd

Wireless network threats are relevant to SecureFlow Sdn. Bhd. because the organization provides separate wireless networks for staff and guest users. The risk of attackers increasingly attempting to exploit wireless communication channels because of the use of wireless access points and multiple SSIDs. Threats such as rogue access point, evil twin attack and wireless password cracking may compromise sensitive customer information, employee credentials and internal business systems. Strong wireless security controls are needed to protect SecureFlow staff and guest user wireless infrastructure from the attacks.

3.5.3 Threat Categories

Threat Name	Category	Likelihood (H/M/L)	Impact (H/M/L)	Affected Layer (OSI)	Recommended Control
Rogue Access Point	Wireless Threat	High	High	Layer 2	Wireless intrusion detection and AP monitoring
Evil Twin Attack	Wireless Threat	High	High	Layer 2	WPA3-Enterprise and user awareness training
WPA2 Cracking	Wireless Threat	Medium	High	Layer 2	Strong WPA3/WPA2 passwords and Enterprise authentication

3.5.4 Threat Explanation

Rogue Access Point

A rogue access point is an unauthorized WiFi access point put in place in the Network environment without approval from Admin/Owner. This type of attack is in the Spoofing category of STRIDE; attacking the legitimate WiFi network to try to obtain access by running a spoofed access point. The likelihood for success is rated as High because hackers are constantly targeting Wireless networks to create fake access points; therefore, the likelihood of users connecting to rogue access points and compromising data (sensitive login credentials, company information, etc.) is rated as High.

Evil Twin Attack

An evil twin attack is a wireless network attack where the attacker creates a fake wireless access point that appears identical to a legitimate network. Users may connect to the malicious access point without notice, allowing the attackers to intercept network traffic, capture login credentials or steal the sensitive information. The likelihood is high because employees and guests may find it difficult to distinguish between the legitimate and malicious wireless network. The impact is high because successful attacks can lead to credential theft, unauthorised network access and exposure of sensitive business information. Recommended control is using WPA3-Enterprise authentication, certificate-based authentication and user security awareness training.

WPA2 Cracking

WPA 2 cracking is a wireless attack where the attacker tries to recover a wireless network password by capturing authentication handshake and performing password guessing attack. Once the password is acquired, attackers may gain unauthorised access to the wireless network and connected resources. The likelihood is medium because the successful attack is based on the password strength and wireless security configurations. The impact is high because unauthorised access to SecureFlow wireless network may expose sensitive customer data and business communications. Recommended controls are implementing WPA3-Enterprise, enforcing strong password policy and regularly updating wireless security configuration.

3.6 Application-Layer Threats

3.6.1 Introduction

Application-layer threats are one of the common cyberattacks target the Application Layer 7 of the OSI model. The threats target software and services including operating systems, email systems, web applications and online services. The attacks can happen by exploiting human behaviour, weak authentication, stealing sensitive information and spreading malware. Nowadays, application-layer threats are considered the most dangerous attack vectors because attackers manipulate users to access malicious links, purchase fake and cheaper-looking services. SecureFlow Sdn. Bhd. that processes sensitive financial and customer data, application-layer threats reveal a serious risk of confidentiality, integrity, information assets.

3.6.2 Relevance to SecureFlow Sdn. Bhd

Application-layer threats are relevant to SecureFlow Sdn. Bhd. because the company handles sensitive financial and customer data through email systems, web applications and online services. Attackers commonly use phishing emails, malware and unauthorised access to target fintech organizations and obtain confidential information. SecureFlow must comply with Malaysia's PDPA 2010 and PCI-DSS rules and regulations. Successful application-layer attacks might lead to data breaches, financial losses, reputational damage and loss of public

trust. Therefore, identifying and mitigating application-layer threats is very important to maintain the organisation's security and trust.

3.6.3 Threat Categories

Threat Name	Category	Likelihood (H/M/L)	Impact (H/M/L)	Affected Layer (OSI)	Recommended Control
Phishing-Embedded Malware	Application-Layer	High	High	Layer 7	Email filtering and awareness training
Email Spoofing	Application-Layer	High	Medium	Layer 7	SPF, DKIM and DMARC
SQL Injection (SQLi)	Application-Layer	Medium	High	Layer 7	Input validation and Web Application Firewall (WAF)
Credential Stuffing	Application-Layer	High	High	Layer 7	Multi-factor authentication (MFA)

3.6.4 Threat Explanation

Phishing-Embedded Malware

Phishing-embedded malware is an application-layer attack. Attackers send fraudulent emails that contain malicious attachments or harmful links to trick users to install malware. When the malware is executed, attackers gain unauthorised access to systems, steal confidential information or deploy ransomware inside the organization network. The likelihood of this threat is high because phishing attacks are used against the fintech organizations and employees that interact with emails and online attachments. The impact is also high because successful malware infections will lead to financial losses, data breaches, operational disruption to the SecureFlow Sdn. Bhd. Recommended controls for this threat are email filtering systems, endpoint protection software and security awareness training.

Email Spoofing

Email spoofing is an application-layer attack. Attackers forge email addresses to make messages appear as a originated trusted organisations or legitimate employees and spoofed emails to trick users into revealing sensitive information, downloading malware or performing fraudulent financial transactions. The likelihood of this threat is high because fintech organisations rely on email communication for daily operations and interaction with customers. The impact is medium because successful spoofing attacks may damage SecureFlow reputation, expose confidential information and reduce trust of customers in the organisations communication systems. Recommended controls for this threat are implementing SPF, DKIM and DMARC protocols.

SQL Injection (SQLi)

SQL Injection (SQLi) is an application-layer attack. Attackers inject malicious SQL commands into web application input fields to manipulate backend databases. This will allow attackers to avoid the authentication mechanisms, retrieve sensitive customer information, modify the records or delete critical data in the database. The likelihood of this threat is medium because fintech organisations rely heavily on web applications that interact with databases. The impact is high because successful SQL injection attacks can affect data breaches, financial losses and damage to SecureFlow Sdn. Bhd. reputation. Recommended control for this threat is input validation, secure coding practices and regular web application security testing.

Credential Stuffing

Credential stuffing is a type of attack that targets users by stealing usernames and passwords through hacking. Attackers use software programs to enter a lot of usernames and/or passwords into a system. Because so many people reuse the same password across several different organisations, there is a high likelihood of success for the attacker. If the attacker succeeds, there are potentially devastating results, including financial losses, data theft, and loss to the reputation of SecureFlow Sdn. Bhd. Multi-Factor Authentication (MFA), strong passwords, CAPTCHA testing, and monitoring for suspicious logins are some recommended methods for mitigating risk from credential stuffing.

3.7 Vulnerability Assessment Matrix

Threat Name	Category	Likelihood (H/M/L)	Impact (H/M/L)	Affected Layer (OSI)	Recommended Control
Eavesdropping	Passive Attack	Medium	High	Layer 2 (Data Link)	VPN encryption and secure communication protocols
Traffic Analysis	Passive Attack	Medium	Medium	Layer 2 (Data Link)	Network encryption and traffic monitoring
Man-in-the-Middle (MitM)	Active Attack	High	High	Layer 3 (Network)	TLS encryption and certificate validation
Denial-of-Service (DoS)	Active Attack	High	High	Layer 3/4 (Network/Transport)	Firewall filtering and IDS/IPS
Replay Attack	Active Attack	Medium	High	Layer 3/4 (Network/Transport)	Session tokens, timestamps and anti-replay mechanisms
ARP Spoofing	Layer 2 Attack	High	High	Layer 2 (Data Link)	Dynamic ARP Inspection (DAI)
VLAN Hopping	Layer 2 Attack	Medium	High	Layer 2 (Data Link)	Proper VLAN configuration and unused port shutdown
MAC Flooding	Layer 2 Attack	Medium	Medium	Layer 2 (Data Link)	Port Security and MAC address limiting
Rogue Access Point	Wireless Threat	High	High	Layer 2 (Data Link)	Wireless intrusion detection and AP monitoring
Evil Twin Attack	Wireless Threat	High	High	Layer 2 (Data Link)	WPA3-Enterprise and user awareness training
WPA2 Cracking	Wireless Threat	Medium	High	Layer 2 (Data Link)	Strong WPA3/WPA2 passwords and Enterprise authentication
Phishing-Embedded Malware	Application-Layer Threat	High	High	Layer 7 (Application)	Email filtering and awareness training
Email Spoofing	Application-Layer Threat	High	Medium	Layer 7 (Application)	SPF, DKIM, and DMARC implementation
SQL Injection	Application-	Medium	High	Layer 7	Input validation and Web

(SQLi)	Layer Threat			(Application)	Application Firewall (WAF)
Credential Stuffing	Application-Layer Threat	High	High	Layer 7 (Application)	Multi-factor authentication (MFA)

3.8 Closing paragraph

Based upon the results of the assessment, SecureFlow Sdn. Bhd. has a variety of cybersecurity risks which could lead to potential threats against the confidentiality, integrity and availability of its systems and the financial data of its customers. These identified threats primarily target the organisation's network communications, wireless infrastructure, internal segmentation and user communication systems; and without adequate security controls in place, these risks can cause service outages, unauthorised access to systems, significant financial loss and damage to the organisation's reputation.

Through the use of the STRIDE threat modelling framework, SecureFlow has also been able to create a more structured method of identifying and analysing the various threats facing its enterprise network environment. Additionally, SecureFlow will benefit from implementing recommended security controls, such as: VLAN segmentation, Dynamic ARP Inspection (DAI), IDS/IPS, VPN encryption, firewall filtering and employee awareness training; and thereby improve its overall security posture for the enterprise network, as well as reduce the likelihood of cyberattacks occurring in the future.

4. Network Architecture and Hardening Evidence

Network topology diagram, configuration evidence (screenshots), and narrative justification for design decisions.

4.1 Network Topology

Using a defence-in-depth strategy, the design of the network's architecture includes multiple layers of security to protect different areas of the network from attacks. Rather than depending upon one security measure to secure an area of the network, there are multiple layers of controls positioned at various locations throughout the network that will help limit the attack when one layer is compromised.

To accommodate for this, the network has been divided into four separate security zones - the Internet Zone, DMZ Zone, Internal LAN Zone and Branch Office Zone. Each zone serves its own purpose and has been given a unique level of trust. By separating the security zones, it limits the amount of direct access that exists between the different segments of the network and helps to limit an attacker's ability to freely move through the network after they have gained access to one particular security zone.

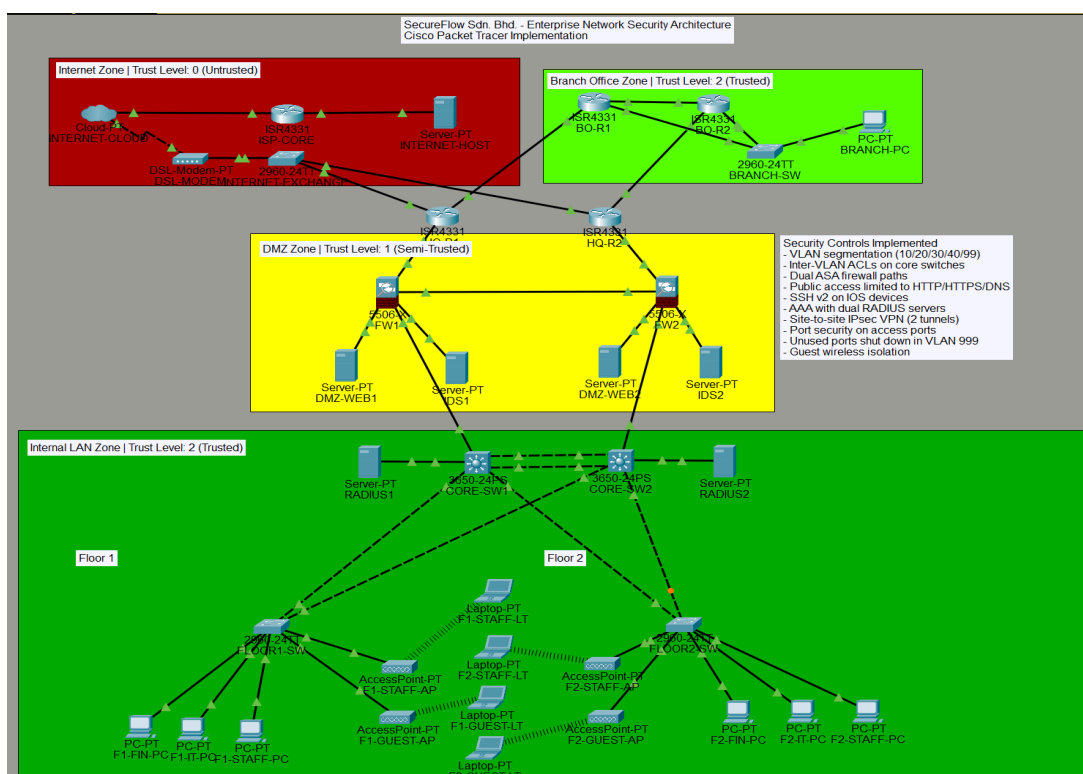


Figure 4.1: Final SecureFlow enterprise topology showing Internet, DMZ, Internal LAN, Guest Wireless, and Branch Office zones

4.2 Internet Zone

The Internet Zone represents the untrusted external environment and contains the simulated Internet cloud, DSL modem, Internet exchange segment, ISP-CORE router, and the external validation host (INTERNET-HOST). This zone was designed with trust level 0 because it represents networks outside organisational control. The headquarters edge routers, HQ-R1 and HQ-R2, connect the internal enterprise environment to this external segment through controlled perimeter routing and NAT policies.

The Internet-facing design was hardened by restricting inbound exposure to approved public services only, specifically HTTP, HTTPS, and DNS to the DMZ web infrastructure. Direct access from the Internet to internal RFC1918 address space was blocked using perimeter ACLs and anti-spoofing rules. Outbound internal traffic was translated using PAT, while public web publication was achieved using static NAT mappings to the DMZ servers.

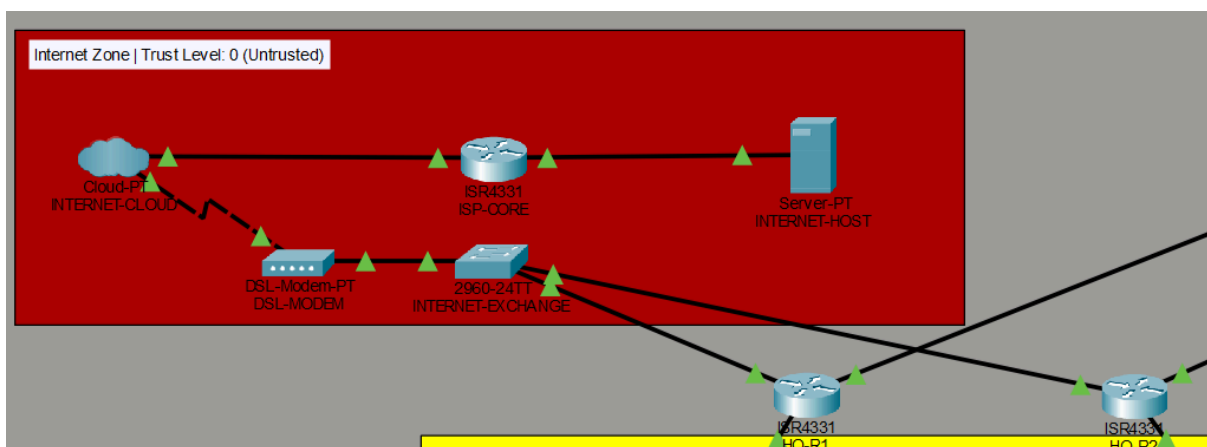


Figure 4.2: Full or cropped Internet Zone topology

```

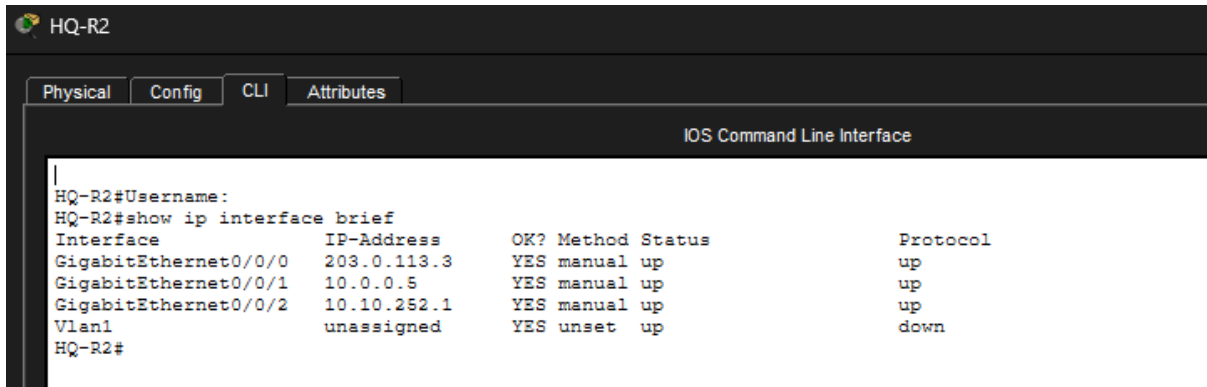
HQ-R1
Physical Config CLI Attributes
IOS Command Line Interface

Username: netadmin
Password:
HQ-R1>enable
Password:
|

HQ-R1#show ip interface brief
Interface      IP-Address      OK? Method Status      Protocol
GigabitEthernet0/0/0  203.0.113.2    YES manual up          up
GigabitEthernet0/0/1  10.0.0.1       YES manual up          up
GigabitEthernet0/0/2  10.10.251.1    YES manual up          up
Vlan1          unassigned     YES unset  administratively down down
HQ-R1#

```

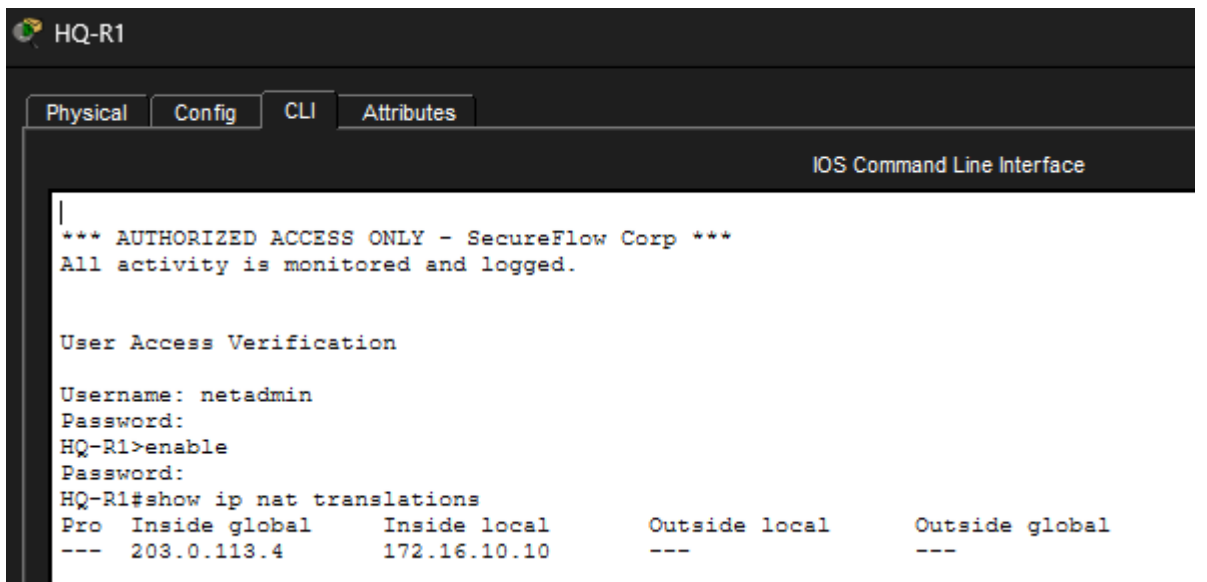
Figure 4.3: HQ-R1 ip interface



The screenshot shows the HQ-R2 CLI interface with the 'CLI' tab selected. The command 'show ip interface brief' has been executed, displaying a table of interface configurations.

Interface	IP-Address	OK?	Method	Status	Protocol
GigabitEthernet0/0/0	203.0.113.3	YES	manual	up	up
GigabitEthernet0/0/1	10.0.0.5	YES	manual	up	up
GigabitEthernet0/0/2	10.10.252.1	YES	manual	up	up
Vlan1	unassigned	YES	unset	up	down

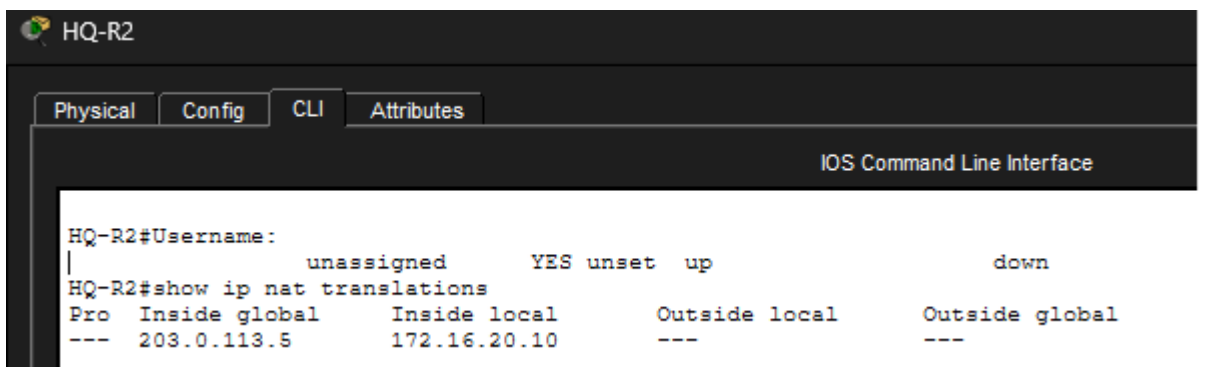
Figure 4.4: HQ-R2 ip interface



The screenshot shows the HQ-R1 CLI interface with the 'CLI' tab selected. The command 'show ip nat translations' has been executed, displaying a table of NAT translations.

Pro	Inside global	Inside local	Outside local	Outside global
---	203.0.113.4	172.16.10.10	---	---

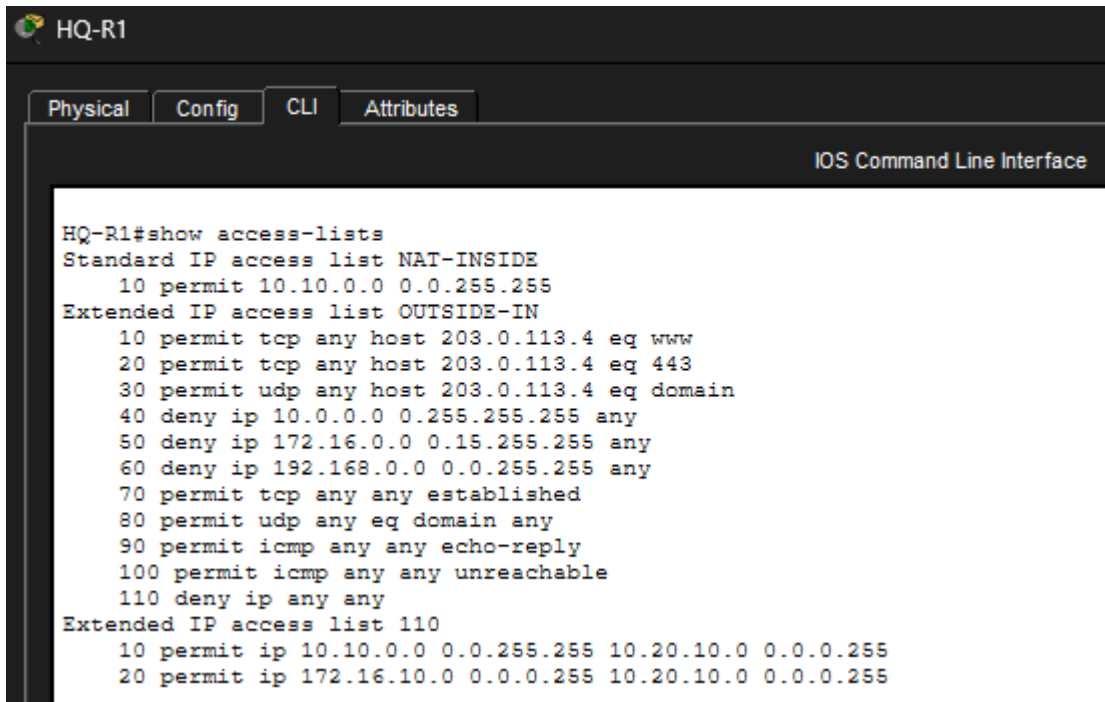
Figure 4.5: HQ-R1 ip nat translations



The screenshot shows the HQ-R2 CLI interface with the 'CLI' tab selected. The command 'show ip nat translations' has been executed, displaying a table of NAT translations.

Pro	Inside global	Inside local	Outside local	Outside global
---	203.0.113.5	172.16.20.10	---	---

Figure 4.6: HQ-R2 ip nat translations



The screenshot shows the CLI of a router named HQ-R1. The 'CLI' tab is selected. The command 'show access-lists' has been entered, displaying the following configuration:

```
HQ-R1#show access-lists
Standard IP access list NAT-INSIDE
 10 permit 10.10.0.0 0.0.255.255
Extended IP access list OUTSIDE-IN
 10 permit tcp any host 203.0.113.4 eq www
 20 permit tcp any host 203.0.113.4 eq 443
 30 permit udp any host 203.0.113.4 eq domain
 40 deny ip 10.0.0.0 0.255.255.255 any
 50 deny ip 172.16.0.0 0.15.255.255 any
 60 deny ip 192.168.0.0 0.0.255.255 any
 70 permit tcp any any established
 80 permit udp any eq domain any
 90 permit icmp any any echo-reply
100 permit icmp any any unreachable
110 deny ip any any
Extended IP access list 110
 10 permit ip 10.10.0.0 0.0.255.255 10.20.10.0 0.0.0.255
 20 permit ip 172.16.10.0 0.0.0.255 10.20.10.0 0.0.0.255
```

Figure 4.7: HQ-R1 access lists

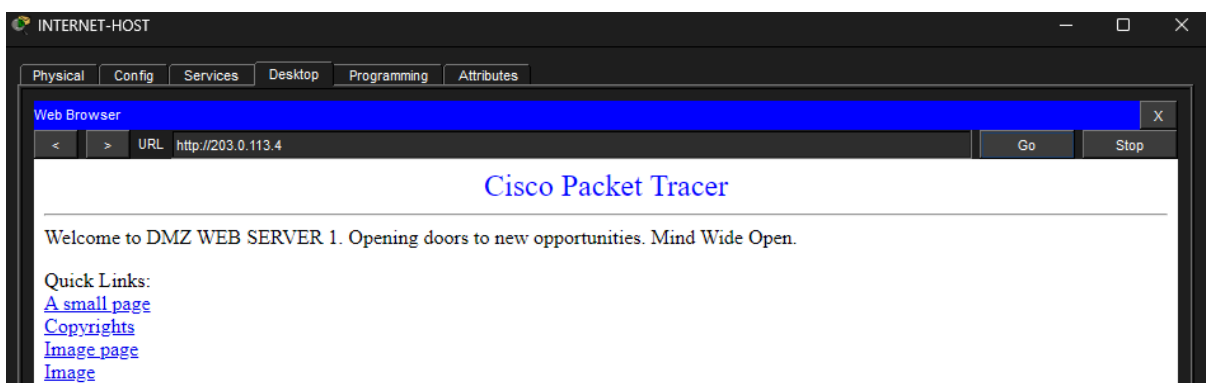


Figure 4.8: Internet-host surf to DMZ server

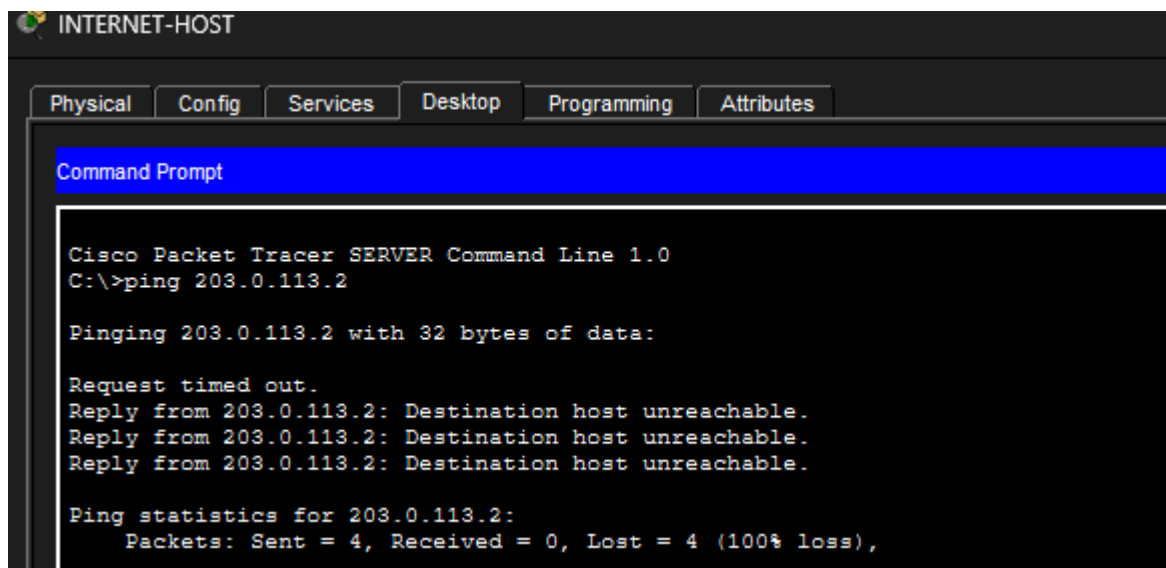


Figure 4.9: Internet-host got blocked by ping to 203.0.113.2

4.3 DMZ Zone

The DMZ Zone was implemented as a semi-trusted security zone (trust level 1) to host public facing services while preventing direct exposure of the internal LAN. The DMZ contains two firewalls (FW1 and FW2), two web/DNS servers (DMZ-WEB1 and DMZ-WEB2), and two IDS placeholder systems (IDS1 and IDS2). This design supports both segmentation and service resilience.

The DMZ was used to isolate Internet-accessible services from internal corporate assets. Public requests terminate at the DMZ web servers rather than at internal hosts. Dual web servers provide redundancy, while the firewalls enforce traffic separation across outside, inside, dmz, and ids interfaces. Packet Tracer limitations prevented use of a real IDS/IPS appliance, so Server-PT nodes were used as placeholders to demonstrate intended IDS placement.

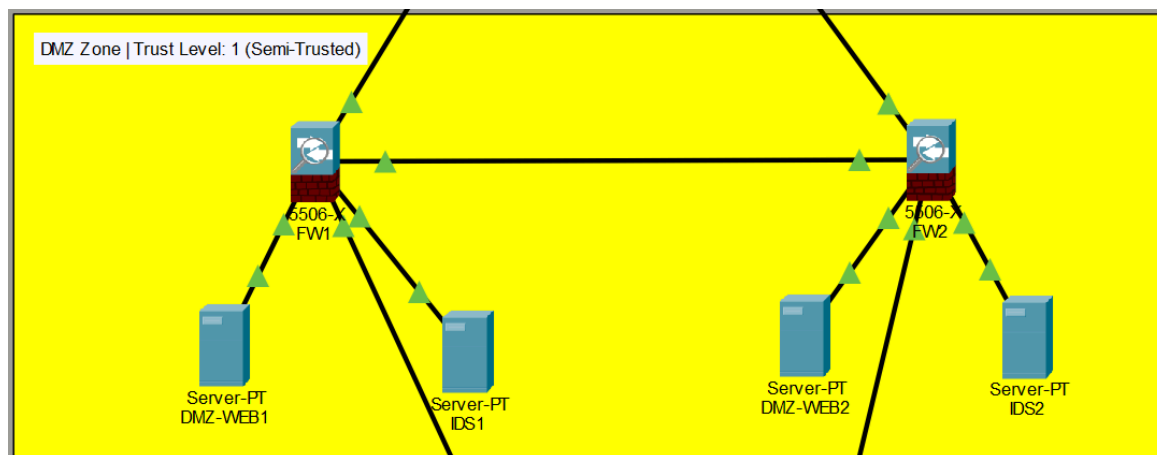


Figure 4.10: DMZ zone


```
FW1>enable
Password:
FW1#show interface ip brief
```

Interface	IP-Address	OK?	Method	Status	Protocol
Virtual0	127.1.0.1	YES	unset	up	up
GigabitEthernet1/1	10.10.253.1	YES	manual	up	up
GigabitEthernet1/2	10.10.251.2	YES	manual	up	up
GigabitEthernet1/3	172.16.10.1	YES	manual	up	up
GigabitEthernet1/4	172.16.11.1	YES	manual	up	up
GigabitEthernet1/5	unassigned	YES	unset	administratively down	down
GigabitEthernet1/6	10.10.250.1	YES	manual	up	up
GigabitEthernet1/7	unassigned	YES	unset	administratively down	down
GigabitEthernet1/8	unassigned	YES	unset	administratively down	down
Management1/1	unassigned	YES	unset	administratively down	down
Internal-Controll1/1	127.0.1.1	YES	unset	up	up
Internal-Data1/1	unassigned	YES	unset	up	up
Internal-Data1/2	unassigned	YES	unset	up	up
Internal-Data1/3	unassigned	YES	unset	up	up

```
FW1#
```

Figure 4.11: Firewall1 ip interface

```
FW2>enable
Password:
FW2#show interface ip brief
```

Interface	IP-Address	OK?	Method	Status	Protocol
Virtual0	127.1.0.1	YES	unset	up	up
GigabitEthernet1/1	10.10.253.2	YES	manual	up	up
GigabitEthernet1/2	10.10.252.2	YES	manual	up	up
GigabitEthernet1/3	172.16.20.1	YES	manual	up	up
GigabitEthernet1/4	172.16.21.1	YES	manual	up	up
GigabitEthernet1/5	unassigned	YES	unset	administratively down	down
GigabitEthernet1/6	10.10.250.5	YES	manual	up	up
GigabitEthernet1/7	unassigned	YES	unset	administratively down	down
GigabitEthernet1/8	unassigned	YES	unset	administratively down	down
Management1/1	unassigned	YES	unset	administratively down	down
Internal-Controll1/1	127.0.1.1	YES	unset	up	up
Internal-Data1/1	unassigned	YES	unset	up	up
Internal-Data1/2	unassigned	YES	unset	up	up
Internal-Data1/3	unassigned	YES	unset	up	up

```
FW2#
```

Figure 4.12: Firewall2 ip interface

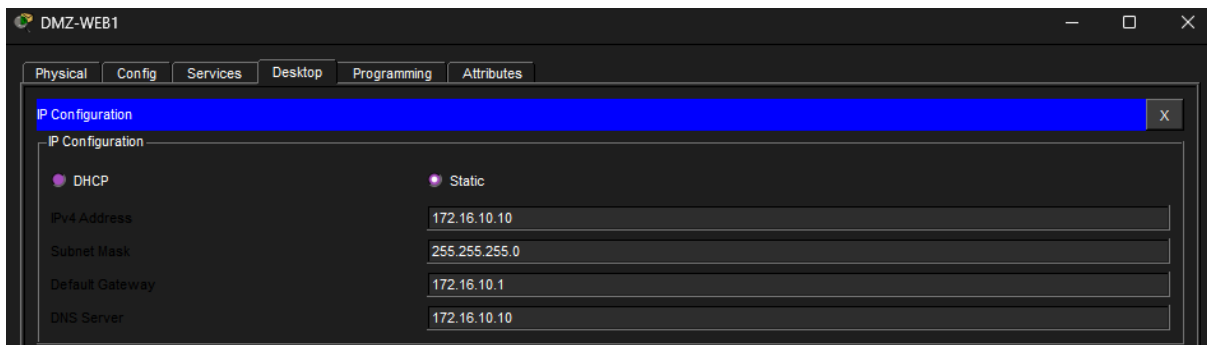


Figure 4.13: DMZ-WEB1 ip configuration

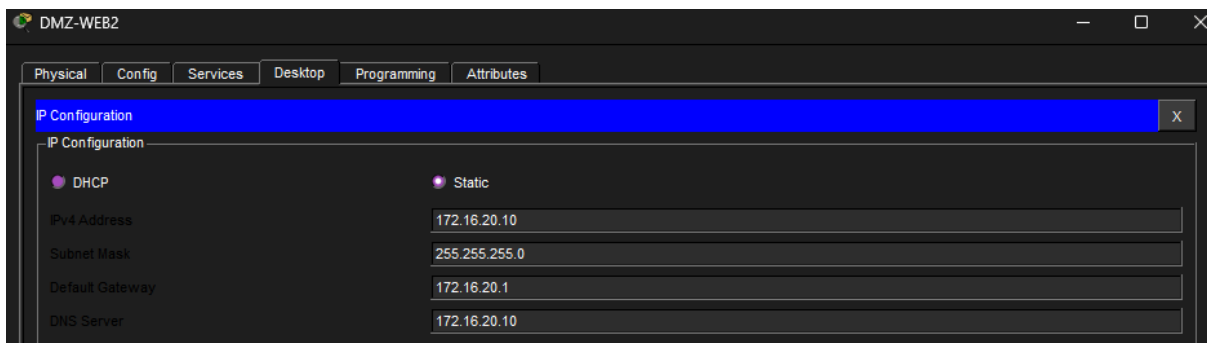


Figure 4.14: DMZ-WEB2 ip configuration

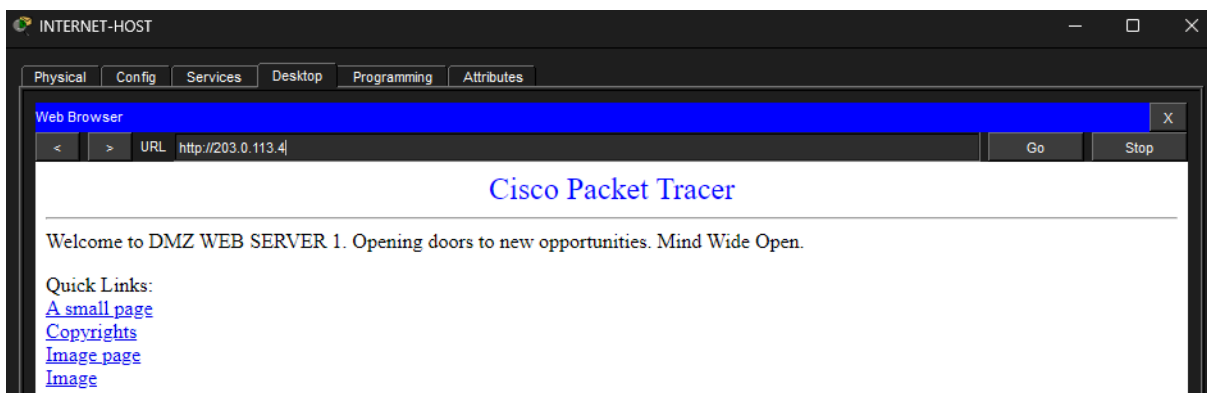


Figure 4.15: Functional validation of DMZ web service accessibility.

4.4 Internal LAN Zone

The Internal LAN Zone was created as a trusted enterprise network (trust level 2) divided into many different VLANs when grouping by business function. The VLAN consist of:

VLAN 10 - Finance

VLAN 20 -

IT VLAN 30 -

Staff VLAN 40 - Guest

VLAN 99 - Management

VLAN 999 - Blackhole / Unclaimed Ports

The two Layer 3 Core Switches (CORE-SW1 and CORE-SW2) provide inter-VLAN routing. The redundancy of the default gateways is achieved through HSRP. Therefore end devices must use just one virtual gateway address when one of the two core switches fail. This allows redundancy for the end devices while also removing the default gateway as an individual failure point, as it has two active redundant gateways. Trunk links between the core switches and the floor switches participate in propagating VLANs. Rapid-PVST provides loop protection and quick Layer 2 recovery.

The hardening of the LAN is further supported through the implementation of port-security to user-facing switch ports, while placing unused ports into VLAN 999 with an administrative shutdown. This reduces the probability that a rogue device will be inserted into the network and/or that unused ports can be accidentally accessed.

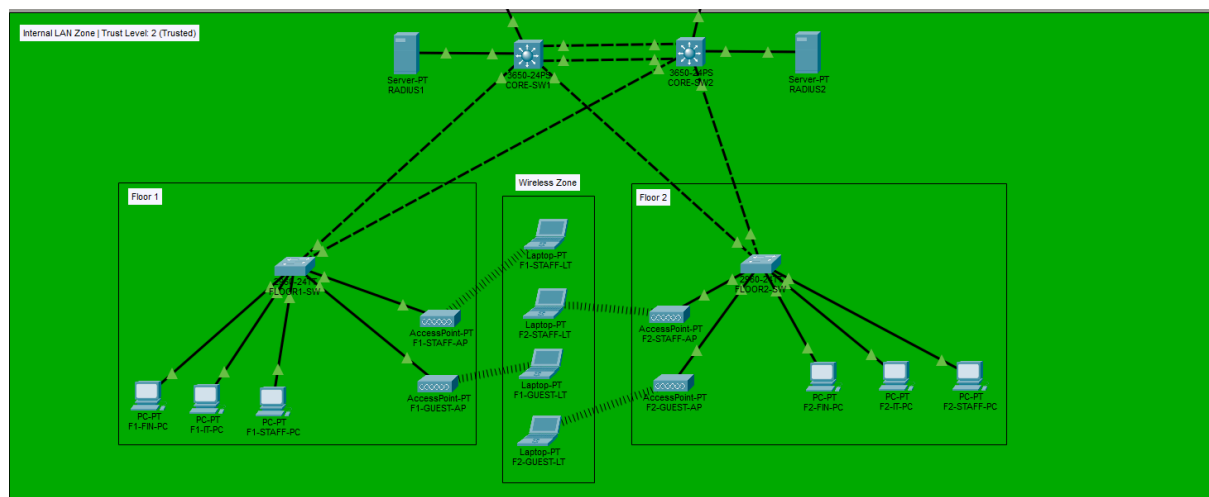


Figure 4.16: Internal LAN topology

CORE-SW1
 Physical Config CLI Attributes
 IOS Command Line Interface
 Username: netadmin
 Password:
 CORE-SW1>enable
 Password:
 CORE-SW1#show vlan brief

VLAN	Name	Status	Ports
1	default	active	Gig1/0/2, Gig1/0/4, Gig1/0/5, Gig1/0/6 Gig1/0/7, Gig1/0/8, Gig1/0/9, Gig1/0/12 Gig1/0/13, Gig1/0/14, Gig1/0/15, Gig1/0/16 Gig1/0/17, Gig1/0/18, Gig1/0/19, Gig1/0/20 Gig1/0/21, Gig1/0/22, Gig1/1/1, Gig1/1/2 Gig1/1/3, Gig1/1/4
10	FINANCE	active	
20	IT	active	Gig1/0/3
30	STAFF	active	
40	GUEST	active	
99	MANAGEMENT	active	
100	CORE-TRANSIT	active	
999	BLACKHOLE	active	
1002	fdi-default	active	
1003	token-ring-default	active	
1004	fdinet-default	active	
1005	trnet-default	active	

CORE-SW1#

Figure 4.17: CORE-SW1 show vlan brief

CORE-SW2
 Physical Config CLI Attributes
 IOS Command Line Interface
 User Access Verification
 Username: netadmin
 Password:
 CORE-SW2>enable
 Password:
 CORE-SW2#show vlan brief

VLAN	Name	Status	Ports
1	default	active	Gig1/0/2, Gig1/0/4, Gig1/0/5, Gig1/0/6 Gig1/0/7, Gig1/0/8, Gig1/0/9, Gig1/0/12 Gig1/0/13, Gig1/0/14, Gig1/0/15, Gig1/0/16 Gig1/0/17, Gig1/0/18, Gig1/0/19, Gig1/0/20 Gig1/0/21, Gig1/0/22, Gig1/1/1, Gig1/1/2 Gig1/1/3, Gig1/1/4
10	FINANCE	active	
20	IT	active	Gig1/0/3
30	STAFF	active	
40	GUEST	active	
99	MANAGEMENT	active	
100	CORE-TRANSIT	active	
999	BLACKHOLE	active	
1002	fdi-default	active	
1003	token-ring-default	active	
1004	fdinet-default	active	
1005	trnet-default	active	

CORE-SW2#

Figure 4.18: CORE-SW2 show vlan brief

```
FLOOR1-SW
Physical Config CLI Attributes
IOS Command Line Interface

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification
Username: admin
Password:
FLOOR1-SW>enable
Password:
FLOOR1-SW#show interface trunk
Port      Mode      Encapsulation  Status      Native vlan
Gig0/1    on        802.1q         trunking    1
Gig0/2    on        802.1q         trunking    1

Port      Vlans allowed on trunk
Gig0/1    10,20,30,40,99
Gig0/2    10,20,30,40,99

Port      Vlans allowed and active in management domain
Gig0/1    10,20,30,40,99
Gig0/2    10,20,30,40,99

Port      Vlans in spanning tree forwarding state and not pruned
Gig0/1    10,20,30,40,99
Gig0/2    40
FLOOR1-SW#
```

Figure 4.19: Floor1-SW show interface trunk

```
FLOOR2-SW
Physical Config CLI Attributes
IOS Command Line Interface

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification
Username: netadmin
Password:
* Login invalid

Username: admin
Password:
FLOOR2-SW>enable
Password:
FLOOR2-SW#show interface trunk
Port      Mode      Encapsulation  Status      Native vlan
Gig0/1    on        802.1q         trunking    1
Gig0/2    on        802.1q         trunking    1

Port      Vlans allowed on trunk
Gig0/1    10,20,30,40,99
Gig0/2    10,20,30,40,99

Port      Vlans allowed and active in management domain
Gig0/1    10,20,30,40,99
Gig0/2    10,20,30,40,99

Port      Vlans in spanning tree forwarding state and not pruned
Gig0/1    10,20,30,40,99
Gig0/2    40
```

Figure 4.20: Floor2-SW show interface trunk

Physical Config CLI Attributes

IOS Command Line Interface

```

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification
|
Username: netadmin
Password:
CORE-SW1>enable
Password:
CORE-SW1#show standby brief
                P indicates configured to preempt.
                |
Interface    Grp  Pri  P State    Active        Standby        Virtual IP
Vl10         10   110  P Active   local         10.10.10.3     10.10.10.1
Vl20         20   110  P Active   local         10.10.20.3     10.10.20.1
Vl30         30   110  P Active   local         10.10.30.3     10.10.30.1
Vl40         40   110  P Active   local         10.10.40.3     10.10.40.1
Vl99         99   110  P Active   local         10.10.99.3     10.10.99.1
CORE-SW1#

```

Figure 4.21: CORE-SW1 show standby brief

Physical Config CLI Attributes

IOS Command Line Interface

```

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification
|
Username: netadmin
Password:
CORE-SW2>enable
Password:
CORE-SW2#show standby brief
                P indicates configured to preempt.
                |
Interface    Grp  Pri  P State    Active        Standby        Virtual IP
Vl10         10   100  P Standby  10.10.10.2    local          10.10.10.1
Vl20         20   100  P Standby  10.10.20.2    local          10.10.20.1
Vl30         30   100  P Standby  10.10.30.2    local          10.10.30.1
Vl40         40   100  P Standby  10.10.40.2    local          10.10.40.1
Vl99         99   100  P Standby  10.10.99.2    local          10.10.99.1
CORE-SW2#

```

Figure 4.22: CORE-SW2 show standby brief

```

FLOOR1-SW
Physical Config CLI Attributes
IOS Command Line Interface

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification

Username: admin
Password:
FLOOR1-SW>enable
Password:
FLOOR1-SW#show spanning-tree vlan 10
VLAN0010
  Spanning tree enabled protocol rstp
    Root ID    Priority    24586
              Address    00D0.BC6E.9B79
              Cost        4
              Port        25(GigabitEthernet0/1)
              Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec

    Bridge ID   Priority    32778 (priority 32768 sys-id-ext 10)
              Address    0007.EC6B.4BD8
              Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec
              Aging Time  20

Interface      Role Sts Cost      Prio.Nbr Type
-----
Fa0/1          Desg FWD 19        128.1   P2p
Gi0/1          Root FWD 4         128.25  P2p
Gi0/2          Altn BLK 4         128.26  P2p

```

Figure 4.23: Floor1-SW show spanning-tree vlan 10

```

FLOOR1-SW
Physical Config CLI Attributes
IOS Command Line Interface

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification

Username: admin
Password:
% Login invalid

Username: admin
Password:
FLOOR1-SW>enable
Password:
FLOOR1-SW#show spanning-tree vlan 20
VLAN0020
  Spanning tree enabled protocol rstp
    Root ID    Priority    24596
              Address    00D0.BC6E.9B79
              Cost        4
              Port        25(GigabitEthernet0/1)
              Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec

    Bridge ID   Priority    32788 (priority 32768 sys-id-ext 20)
              Address    0007.EC6B.4BD8
              Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec
              Aging Time  20

Interface      Role Sts Cost      Prio.Nbr Type
-----
Fa0/2          Desg FWD 19        128.2   P2p
Gi0/1          Root FWD 4         128.25  P2p
Gi0/2          Altn BLK 4         128.26  P2p

FLOOR1-SW#

```

Figure 4.24: Floor1-SW show spanning-tree vlan 20

```

FLOOR1-SW
Physical Config CLI Attributes
IOS Command Line Interface

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification

Username: admin
Password:
FLOOR1-SW>enable
Password:

FLOOR1-SW#show spanning-tree vlan 30
VLAN0030
  Spanning tree enabled protocol rstp
    Root ID    Priority    24606
              Address    00D0.BC6E.9B79
              Cost        4
              Port        25 (GigabitEthernet0/1)
              Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec

    Bridge ID  Priority    32798 (priority 32768 sys-id-ext 30)
              Address    0007.EC6B.4BD8
              Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec
              Aging Time  20

Interface      Role Sts Cost      Prio.Nbr Type
-----
Fa0/3          Desg FWD 19        128.3   P2p
Fa0/8          Desg FWD 19        128.8   P2p
Gi0/1          Root FWD 4         128.25  P2p
Gi0/2          Altn BLK 4         128.26  P2p

FLOOR1-SW#

```

Figure 4.25: Floor1-SW show spanning-tree vlan 30

```

FLOOR1-SW
Physical Config CLI Attributes
IOS Command Line Interface

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification

Username: admin
Password:
FLOOR1-SW>enable
Password:

FLOOR1-SW#show spanning-tree vlan 40
VLAN0040
  Spanning tree enabled protocol rstp
    Root ID    Priority    24616
              Address    00D0.BC6E.9B79
              Cost        4
              Port        25 (GigabitEthernet0/1)
              Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec

    Bridge ID  Priority    32808 (priority 32768 sys-id-ext 40)
              Address    0007.EC6B.4BD8
              Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec
              Aging Time  20

Interface      Role Sts Cost      Prio.Nbr Type
-----
Fa0/9          Desg FWD 19        128.9   P2p
Gi0/1          Root FWD 4         128.25  P2p
Gi0/2          Altn BLK 4         128.26  P2p

FLOOR1-SW#

```

Figure 4.26: Floor1-SW show spanning-tree vlan 40


```

FLOOR1-SW
Physical Config CLI Attributes
IOS Command Line Interface

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification
Username: admin
Password:
FLOOR1-SW>enable
Password:
FLOOR1-SW#show spanning-tree vlan 99
VLAN0099
  Spanning tree enabled protocol rstp
  Root ID    Priority    24675
            Address    00D0.BC6E.9B79
            Cost        4
            Port        25(GigabitEthernet0/1)
            Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID  Priority    32867 (priority 32768 sys-id-ext 99)
            Address    0007.EC6B.4BD8
            Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec
            Aging Time   20

Interface    Role Sts Cost        Prio.Nbr Type
-----
Gi0/1        Root FWD 4          128.25 P2p
Gi0/2        Altn BLK 4          128.26 P2p

FLOOR1-SW#

```

Figure 4.27: Floor1-SW show spanning-tree vlan 99

```

CORE-SW1
Physical Config CLI Attributes
IOS Command Line Interface

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification
Username: netadmin
Password:
CORE-SW1>enable
Password:
CORE-SW1#show ip dhcp binding
IP address    Client-ID/      Lease expiration    Type
             Hardware address
10.10.10.121   0009.7CC9.CCD8  --                  Automatic
10.10.10.22    0001.64C4.5CE5  --                  Automatic
10.10.20.121   0040.0B72.48A1  --                  Automatic
10.10.20.22    00D0.D372.AA56  --                  Automatic
10.10.30.121   0003.E490.CD79  --                  Automatic
10.10.30.22    0007.ECE6.AA2E  --                  Automatic
10.10.30.23    0002.164E.2462  --                  Automatic
10.10.30.24    00D0.BA40.2935  --                  Automatic
10.10.40.121   00D0.BC1C.B17E  --                  Automatic
10.10.40.123   0002.17A0.5471  --                  Automatic
CORE-SW1#

```

Figure 4.28: CORE-SW1 show ip dhcp binding

4.5 Guest Wireless Zone

To provide guests and visitors with non-corporate access to the enterprise wireless network without exposing resources within the trusted environment, the corporation implemented a wireless guest zone that was segmented off from the trusted enterprise segments. This guest wireless zone has VLAN 40 assigned to it, and inbound access control lists (ACLs) were used on the core gateways to control guest wireless traffic flow. This network access policy provides guests wireless devices with a limited opportunity to access approved resources on either a DMZ or the wider Internet, but denies guests access to internal enterprise VLANs and the branch office network.

While implementing this guest wireless zone, the Packet Tracer wireless access point (AP) model did not provide all of the expected capabilities for WPA2-Enterprise/RADIUS features. As such, the most viable option for wireless access control was used instead. While both guest wireless segmentation and isolation of traffic from the trusted enterprise segments were demonstrated successfully, the DHCP address assignment and access control validation were the two main points of success.

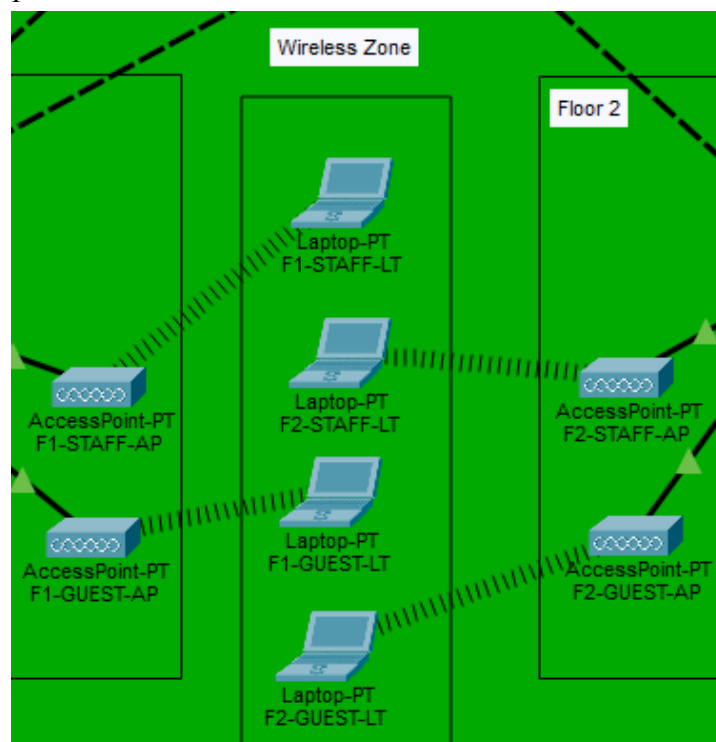


Figure 4.29: Wireless Zone Topology

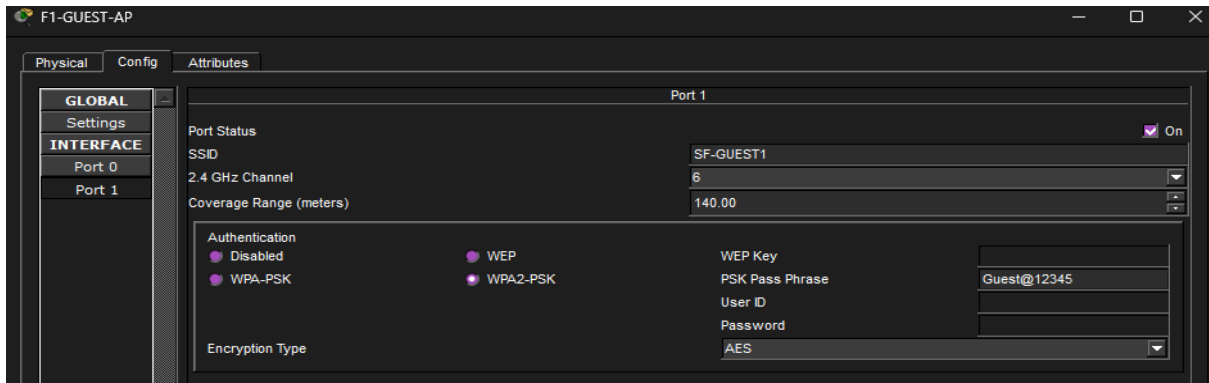


Figure 4.30: Guest Access Point Config

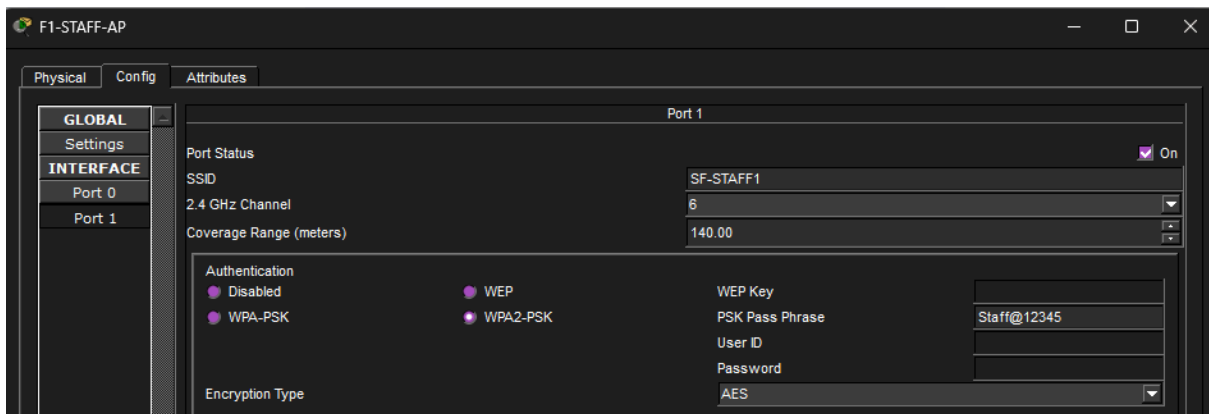


Figure 4.31: Staff Access Point Config

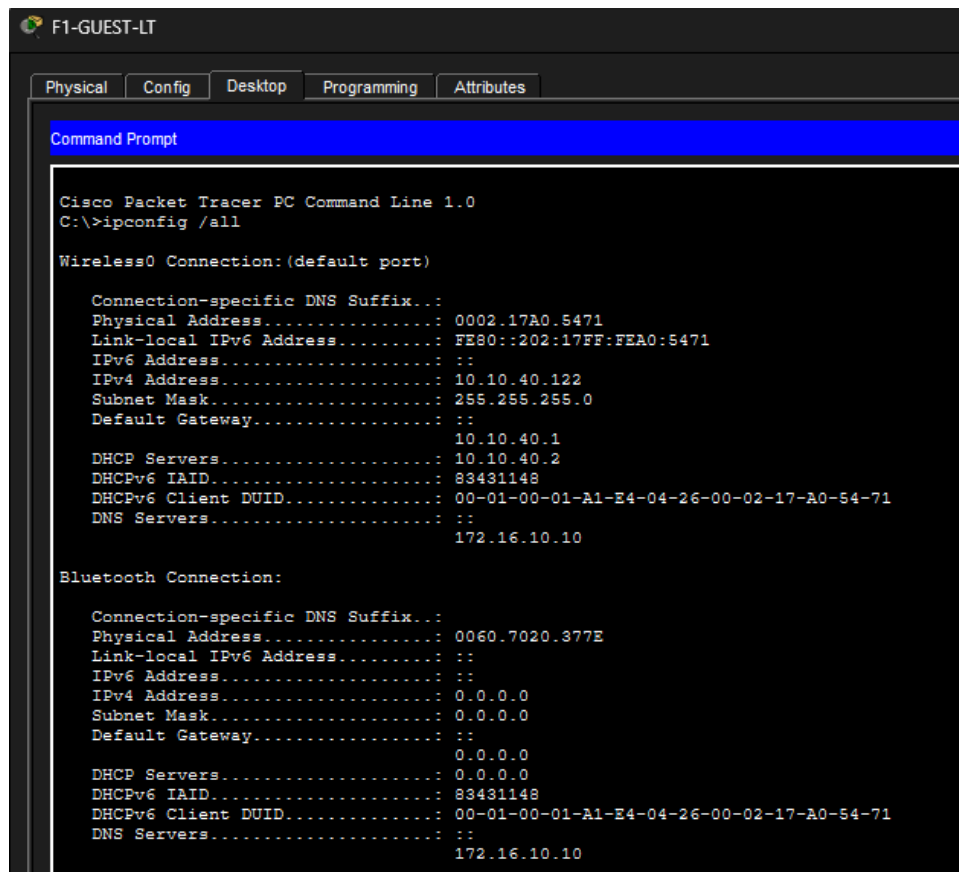


Figure 4.32: Guest laptop IP configuration

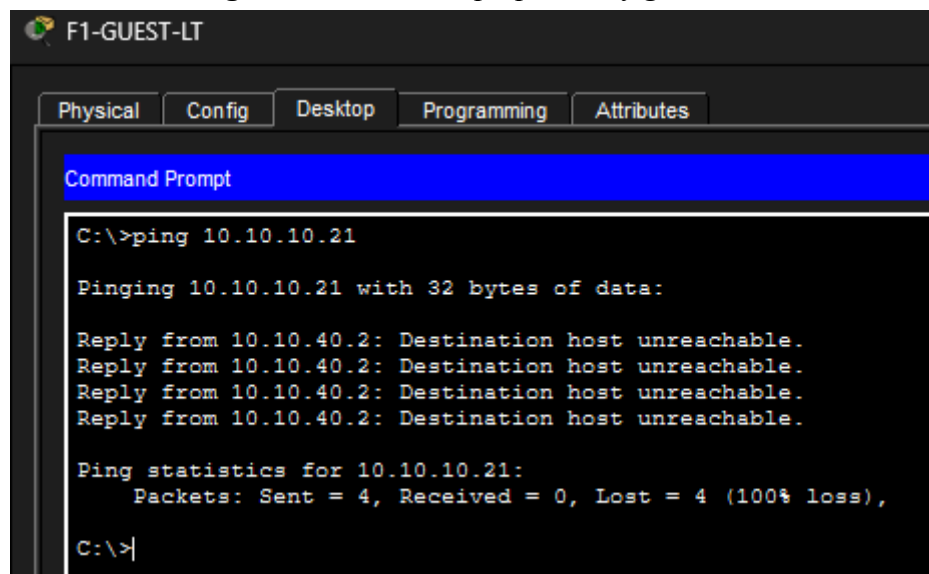


Figure 4.33: Guest laptop blocked ping to internal network

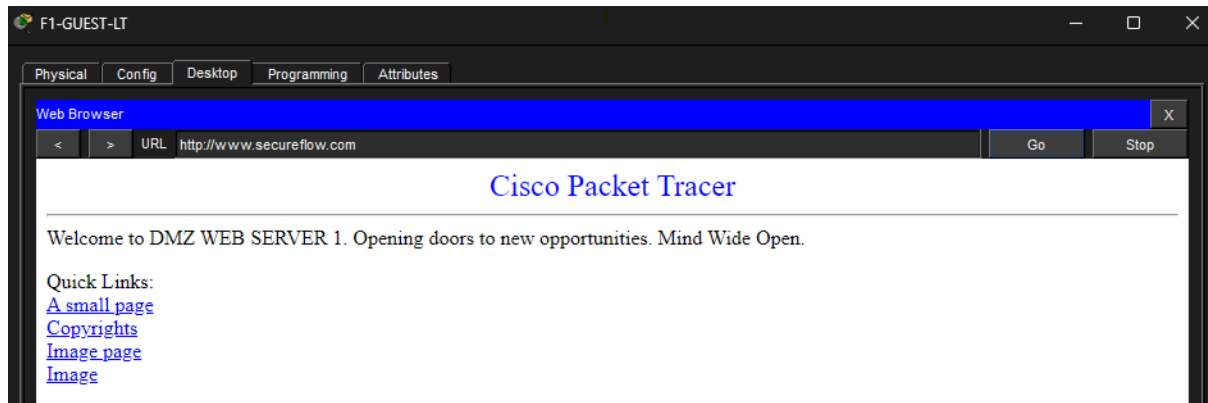


Figure 4.34: Guest laptop browser access to approved web/DMZ service

4.6 Branch Office Zone

The Branch Office Zone was created as a separate, personal remote area that connects back to the main office via two separate routed WANs. Each of the BO-R1 and BO-R2 branches provide redundancy for routing and gateway functions; however, all local branch endpoints connect to a common branch switch - BRANCH-SW. The branch office utilizes HSRP to provide one single virtual default gateway for all devices in that branch office, even if one of the branch routers is down.

Dynamic routing was established by utilizing the OSPF protocol providing both adaptive learning of routes and WAN failover between the branch and the main office. The communication between the main office and the branches that is occurring within the site-to-site network is protected by the use of 2 separate IPsec VPN tunnels - one over each WAN. Thus, the communication between the branches and the HQ is encrypted while maintaining resiliency should either of the WANs fail.

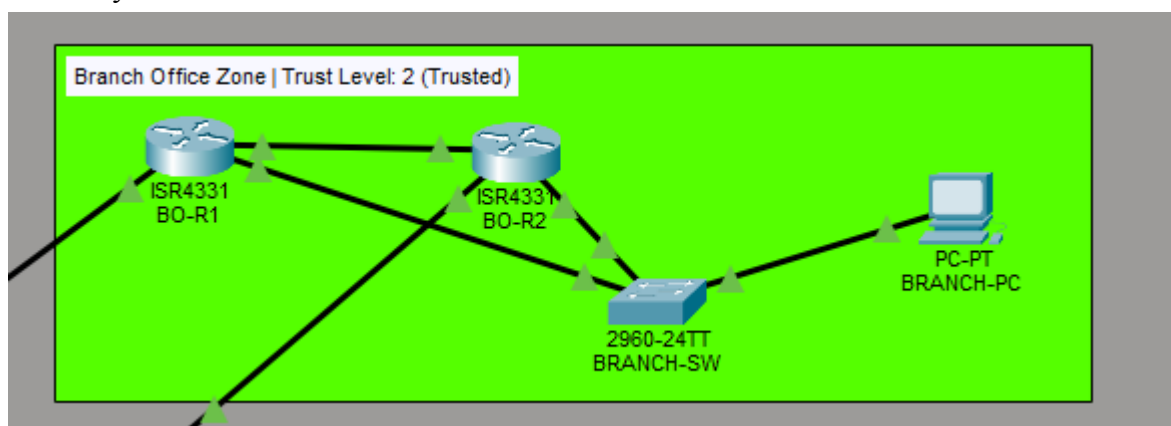


Figure 4.35: Branch Office Zone



Physical
Config
CLI
Attributes

IOS Command Line Interface

```

*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification

Username: netadmin
Password:
BO-R1>enable
Password:
BO-R1#show standby brief
                P indicates configured to preempt.
                |
Interface  Grp  Pri P State   Active        Standby        Virtual IP
Gig0/0/2   1    110 P Active  local         10.20.10.3     10.20.10.1
BO-R1#

```

Figure 4.36: BO-R1 show standby brief



Physical
Config
CLI
Attributes

IOS Command Line Interface

```

BO-R2#
BO-R2#show standby brief
                P indicates configured to preempt.
                |
Interface  Grp  Pri P State   Active        Standby        Virtual IP
Gig0/0/2   1    100 P Standby  10.20.10.2     local          10.20.10.1
BO-R2#
|

```

Figure 4.37: BO-R2 show standby brief



Physical
Config
CLI
Attributes

IOS Command Line Interface

```

|
*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification

Username: netadmin
Password:
BO-R1>enable
Password:
BO-R1#show ip ospf neighbor

Neighbor ID    Pri   State           Dead Time   Address        Interface
4.4.4.4        1     FULL/DR         00:00:34   10.20.0.2     GigabitEthernet0/0/0
1.1.1.1        1     FULL/BDR        00:00:34   10.0.0.1      GigabitEthernet0/0/1
BO-R1#

```

Figure 4.38: BO-R1 show ospf neighbor



The screenshot shows the CLI of a device named HQ-R1. The interface has tabs for Physical, Config, CLI, and Attributes, with the CLI tab selected. The title bar indicates it is the 'IOS Command Line Interface'. The terminal output shows a login sequence for 'netadmin' followed by the command 'show ip ospf neighbor'. The output displays a single OSPF neighbor with ID 3.3.3.3, priority 1, in a FULL/DR state, with a dead time of 00:00:34, address 10.0.0.2, and interface GigabitEthernet0/0/1.

```
HQ-R1
Physical Config CLI Attributes
IOS Command Line Interface

|
*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification

Username:
Username: netadmin
Password:
HQ-R1>enable
Password:
Password:

HQ-R1#show ip ospf neighbor

Neighbor ID      Pri   State           Dead Time   Address        Interface
3.3.3.3          1     FULL/DR         00:00:34    10.0.0.2       GigabitEthernet0/0/1
HQ-R1#
```

Figure 4.39: HQ-R1 show ospf neighbor

```
HQ-R1
Physical Config CLI Attributes
IOS Command Line Interface

HQ-R1#show crypto ipsec sa

interface: GigabitEthernet0/0/1
  Crypto map tag: VPN-MAP, local addr 10.0.0.1

  protected vrf: (none)
  local ident (addr/mask/prot/port): (10.10.0.0/255.255.0.0/0/0)
  remote ident (addr/mask/prot/port): (10.20.10.0/255.255.255.0/0/0)
  current_peer 10.0.0.2 port 500
    PERMIT, flags={origin_is_acl,}
    #pkts encaps: 519, #pkts encrypt: 519, #pkts digest: 0
    #pkts decaps: 520, #pkts decrypt: 520, #pkts verify: 0
    #pkts compressed: 0, #pkts decompressed: 0
    #pkts not compressed: 0, #pkts compr. failed: 0
    #pkts not decompressed: 0, #pkts decompress failed: 0
    #send errors 0, #recv errors 17

    local crypto endpt.: 10.0.0.1, remote crypto endpt.:10.0.0.2
    path mtu 1500, ip mtu 1500, ip mtu idb GigabitEthernet0/0/1
    current outbound spi: 0x0(0)

  inbound esp sas:

  inbound ah sas:

  inbound pcsp sas:

  outbound esp sas:

  outbound ah sas:

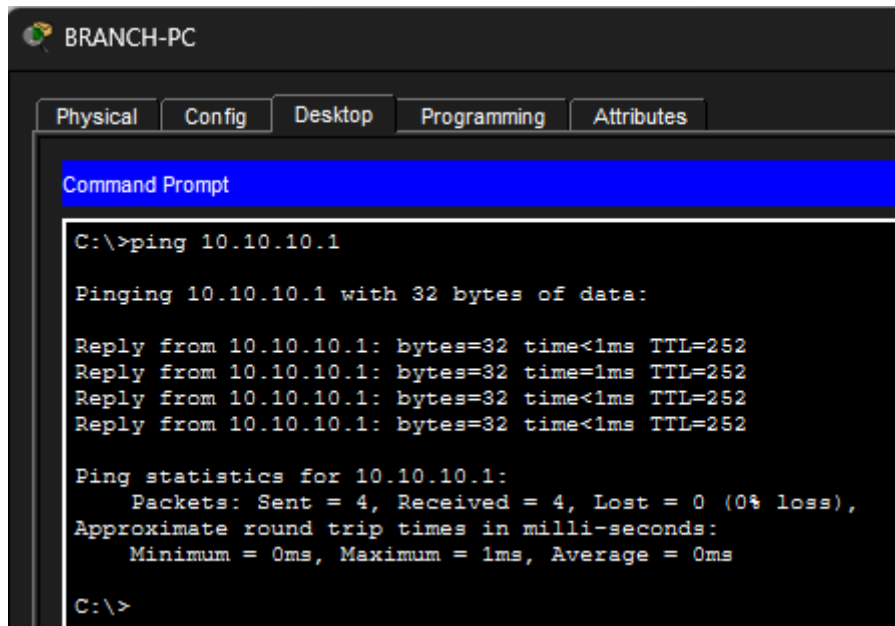
  outbound pcsp sas:

  local ident (addr/mask/prot/port): (172.16.10.0/255.255.255.0/0/0)
  remote ident (addr/mask/prot/port): (10.20.10.0/255.255.255.0/0/0)
  current_peer 10.0.0.2 port 500
    PERMIT, flags={origin_is_acl,}
    #pkts encaps: 0, #pkts encrypt: 0, #pkts digest: 0
    #pkts decaps: 0, #pkts decrypt: 0, #pkts verify: 0
    #pkts compressed: 0, #pkts decompressed: 0
    #pkts not compressed: 0, #pkts compr. failed: 0
    #pkts not decompressed: 0, #pkts decompress failed: 0
    #send errors 0, #recv errors 0

    local crypto endpt.: 10.0.0.1, remote crypto endpt.:10.0.0.2
    path mtu 1500, ip mtu 1500, ip mtu idb GigabitEthernet0/0/1
    current outbound spi: 0x0(0)

  . . .
```

Figure 4.40: HQ-R1 show crypto ipsec sa

The image shows a screenshot of a Windows desktop environment. At the top, there is a taskbar with a single icon labeled 'BRANCH-PC'. Below the taskbar, there are five tabs: 'Physical', 'Config', 'Desktop', 'Programming', and 'Attributes'. The 'Desktop' tab is currently selected. Below the tabs, there is a 'Command Prompt' window. The command prompt shows the following text:

```
C:\>ping 10.10.10.1

Pinging 10.10.10.1 with 32 bytes of data:

Reply from 10.10.10.1: bytes=32 time<1ms TTL=252
Reply from 10.10.10.1: bytes=32 time=1ms TTL=252
Reply from 10.10.10.1: bytes=32 time<1ms TTL=252
Reply from 10.10.10.1: bytes=32 time<1ms TTL=252

Ping statistics for 10.10.10.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 1ms, Average = 0ms

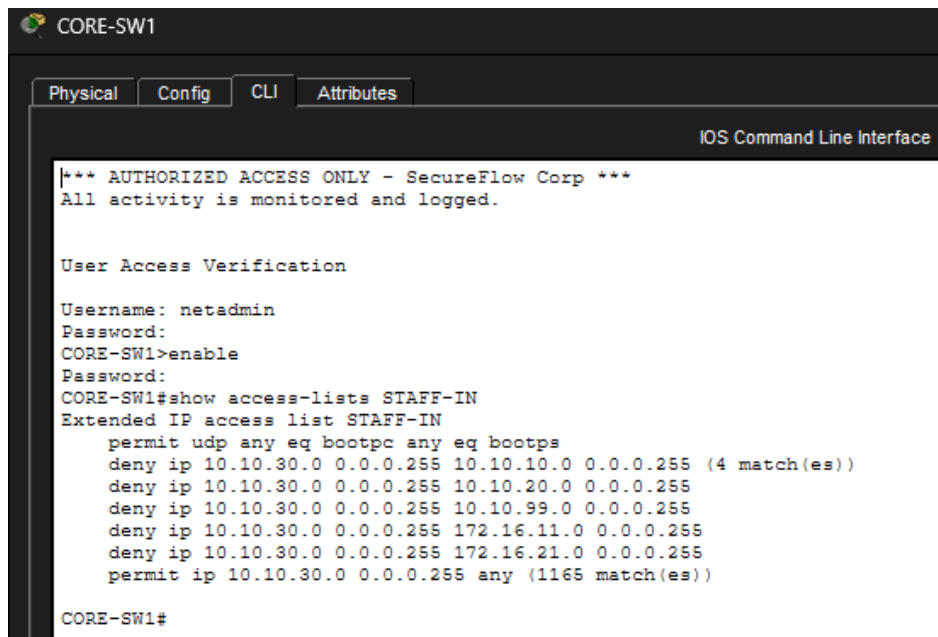
C:\>
```

Figure 4.41: Branch PC ping to LAN (IT-PC; 10.10.10.1)

4.7 Cross-Zone Security and High Availability

There are multiple layers of defence-in-depth established by implementing several security controls across all areas of the enterprise architecture. There are numerous points within the traffic flow where security rules are enforced; at the perimeter, which includes access list controls on the routers, to the firewall separating the internal and DMZ networks, to the VLAN ACL that exists on each of the core switches, to the hardening of switch ports, SSH administration only, centralized AAA and the encrypted communications for the site-to-site connections.

High availability is also built into the architecture with redundancy existing through dual edge routers, dual firewalls, dual core switches, HSRP virtual gateways, EtherChannel links between the core switches, dual RADIUS servers, dual web servers in the DMZ, and dual VPN tunnels which will ensure that the failure of a device or path will not affect the operation of the entire enterprise network.



```
CORE-SW1
Physical Config CLI Attributes
IOS Command Line Interface

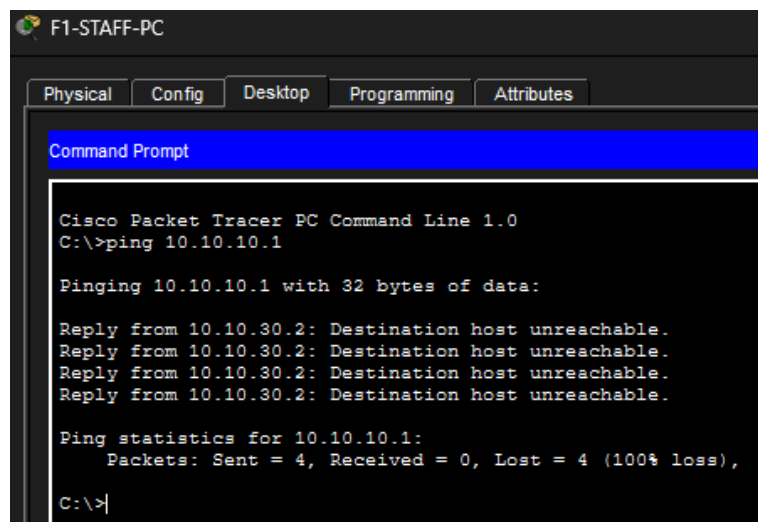
*** AUTHORIZED ACCESS ONLY - SecureFlow Corp ***
All activity is monitored and logged.

User Access Verification

Username: netadmin
Password:
CORE-SW1>enable
Password:
CORE-SW1#show access-lists STAFF-IN
Extended IP access list STAFF-IN
  permit udp any eq bootpc any eq bootps
  deny ip 10.10.30.0 0.0.0.255 10.10.10.0 0.0.0.255 (4 match(es))
  deny ip 10.10.30.0 0.0.0.255 10.10.20.0 0.0.0.255
  deny ip 10.10.30.0 0.0.0.255 10.10.99.0 0.0.0.255
  deny ip 10.10.30.0 0.0.0.255 172.16.11.0 0.0.0.255
  deny ip 10.10.30.0 0.0.0.255 172.16.21.0 0.0.0.255
  permit ip 10.10.30.0 0.0.0.255 any (1165 match(es))

CORE-SW1#
```

Figure 4.33: Enforcement of least-privilege communication between internal VLANs. Staff VLAN traffic to a Finance VLAN host is blocked by the inter-VLAN ACL policy.



```
F1-STAFF-PC
Physical Config Desktop Programming Attributes
Command Prompt

Cisco Packet Tracer PC Command Line 1.0
C:\>ping 10.10.10.1

Pinging 10.10.10.1 with 32 bytes of data:

Reply from 10.10.30.2: Destination host unreachable.
Reply from 10.10.30.2: Destination host unreachable.
Reply from 10.10.30.2: Destination host unreachable.
Reply from 10.10.30.2: Destination host unreachable.

Ping statistics for 10.10.10.1:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),
C:\>|
```

Figure 4.42: Staff-PC ping to IT-PC got blocked

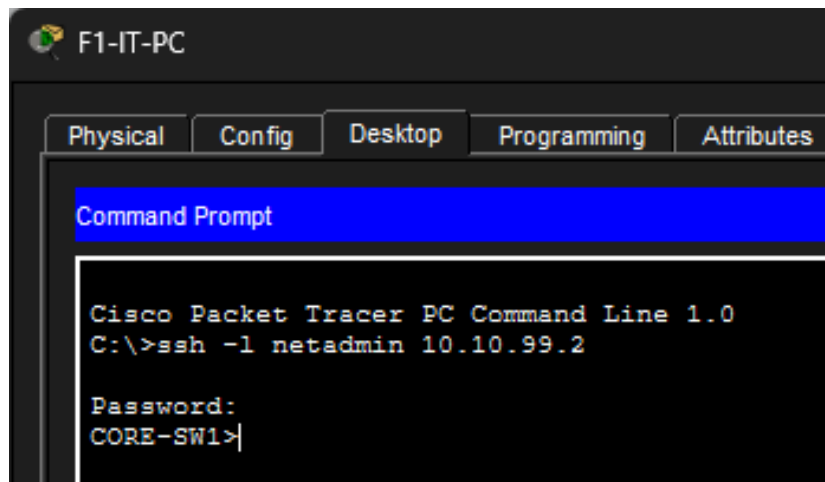


Figure 4.43: Sshlogin into IT-PC

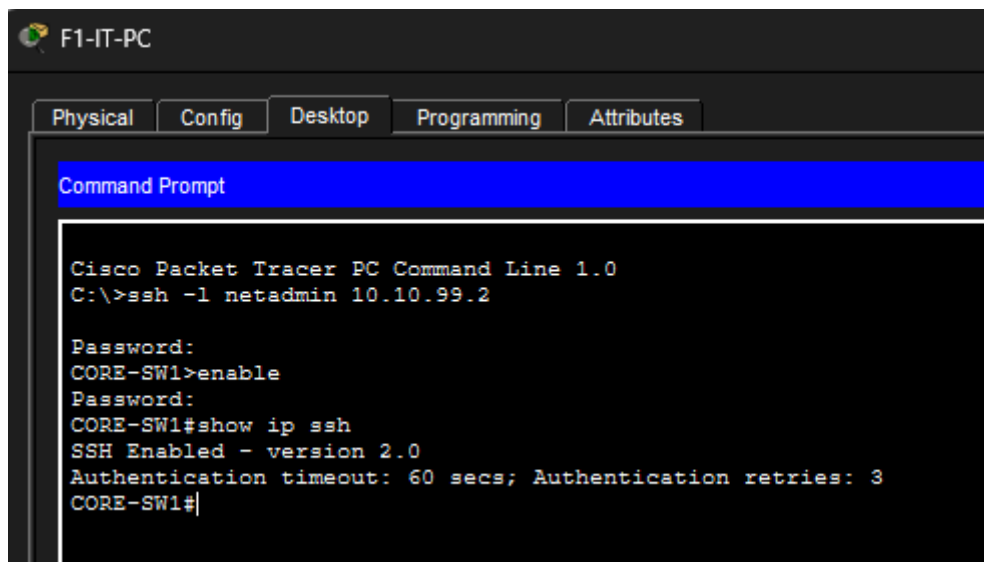


Figure 4.44: Centralized administrative control using SSH and RADIUS AAA. The administrator successfully authenticated to CORE-SW1 using the RADIUS account netadmin over SSHv2.

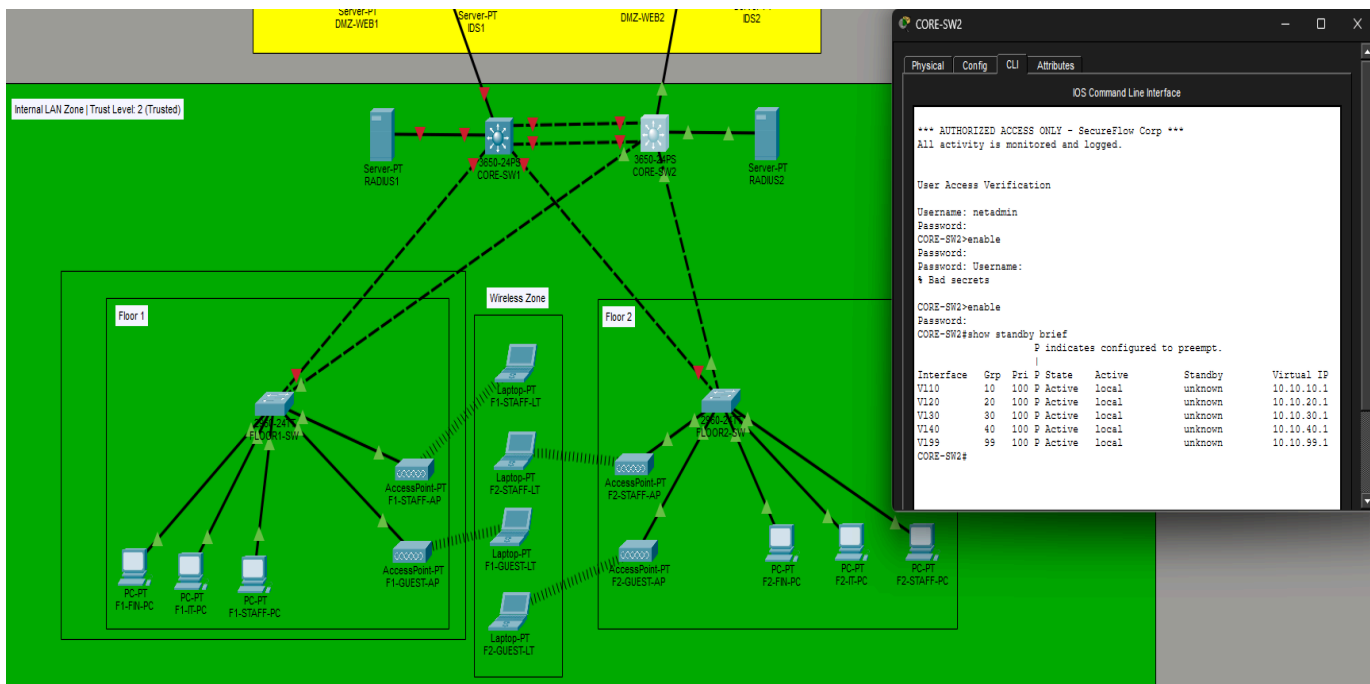


Figure 4.45: CORE-SW1 Fallback and login using backup CORE-SW2

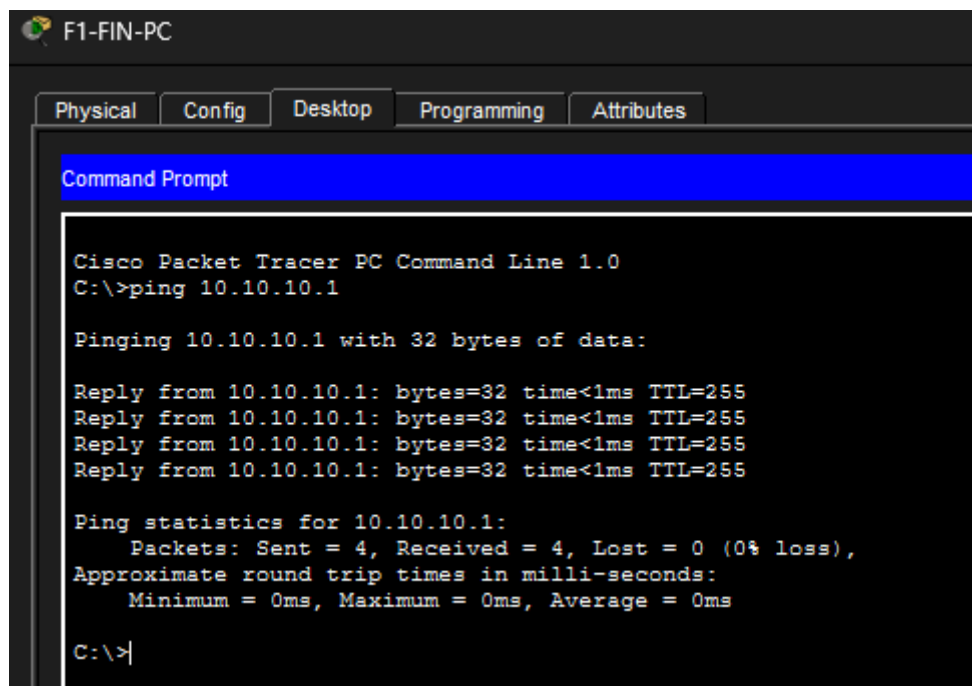


Figure 4.46: Able to ping Finance PC itself

4.8 Packet Tracer Limitations and Design Adaptations

There were a number of decisions made in the implementation of the Packet Tracer that were impacted by the limitations of the Packet Tracer as opposed to the intended design of the Packet Tracer. The decisions made as a result of those limitations were documented and the implementation of the closest technically valid alternative to the original implementation for the Packet Tracer. For instance, the wireless access point (AP) that was used for this lab was configured to not expose any fields allowing for WPA2 (Enterprise/RADIUS) configuration, therefore WPA2 (PSK) was used as a nearest available alternative to provide wireless access; while centralized RADIUS AAA (Authentication, Authorisation and Accounting) was still successfully demonstrated for the administration of the device.

In addition, there were many instances where there were IOS and/or ASA commands that did not match the actual command syntax of the real device or, the commands were not available in Packet Tracer; equivalent fallback commands or simplified configurations were used to maintain the security requirements of the Packet Tracer design. Thus, the Packet Tracer design is still in compliance with enterprise security principals even where exact feature parity between the Packet Tracer and production devices is not available.

5. Security Protocol Evaluation

5.1 TLS 1.2 vs TLS 1.3 Analysis

5.1.1 Introduction

SecureFlow Sdn. Bhd. has built a fin-tech platform that allows user's access to secure and essential financial data and transactions through the use of this platform. Securing communication between users accessing the website and the SecureFlow website servers is a critical consideration for the company to ensure confidentiality, integrity, and continued compliance to regulatory requirements such as those established by the PDPA 2010 and PCI DSS. Communication over HTTPS (HTTP secured using TLS) is accomplished mainly by the use of the TLS protocol.

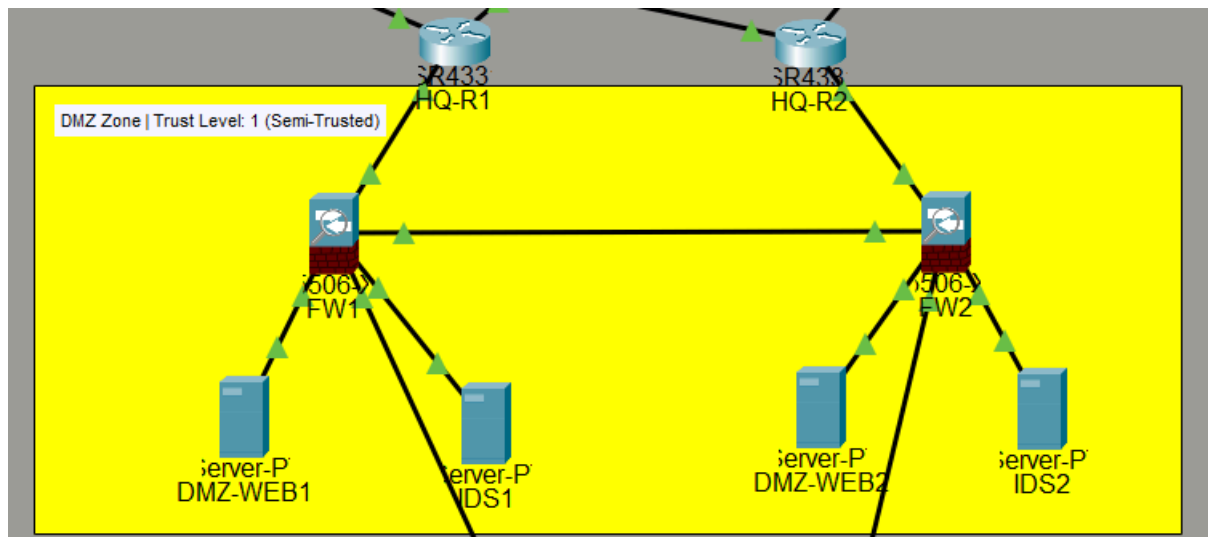


Figure 5.1.1: Public-Facing Web Servers in the DMZ

Figure 5.1.1 shows the public-facing web servers deployed within SecureFlow's DMZ. Customer requests from the Internet are directed to DMZ-WEB1 and DMZ-WEB2 through the perimeter firewalls (FW1 and FW2). Because these servers process sensitive financial information and customer transactions, HTTPS secured by TLS is required to ensure confidentiality, integrity, and authentication of communications.

5.1.2 Cryptographic Improvements in TLS 1.3

Major enhancements to the security features and performance of Transport Layer Security (TLS) [RFC 8446], TLS 1.3 offers many advantages over its predecessor, TLS 1.2. First of all, TLS 1.3 no longer allows insecure and deprecated cryptographic algorithms such as RSA key exchange, SHA-1, RC4, and 3DES. Instead, it supports only strong cipher suites that offer high levels of encryption; therefore, there is less opportunity for malicious users to utilize insecure cryptography for compromising data security through weak implementations of cryptographic services.

Secondly, by eliminating the use of outdated, insecure cryptographic algorithms in addition to implementing ephemeral keys for key exchange, as stated by Rescorla (2018), TLS 1.3 implements forward secrecy. Even in the event that a server's private key is ever compromised, any communication that was intercepted prior to the compromise cannot be decrypted. The ability to ensure security of financial transactions and customer information long after their initial transmission is essential to SecureFlow's business model.

Finally, TLS 1.3 streamlines the overall security protocol by reducing the number of handshake exchanges from two to one (Rescorla, 2018). This reduction in the amount of time needed to complete the initial exchange of system activity between sender/receiver (known as the handshake) improves system performance, reduces website load time, and enhances the overall customer experience.

Feature	TLS 1.2	TLS 1.3
Handshake	2 RTT	1 RTT
Forward Secrecy	Optional	Mandatory
RSA Key Exchange	Supported	Removed
SHA-1	Supported	Removed

5.1.3 Downgrade Attack Considerations

Downgrade Attacks are a type of attack where a malicious individual tricks two networked parties into either downgrading their negotiated version of TLS, or communicating via a less secure protocol. Examples include well known attacks against legacy protocols including POODLE and DROWN which relied on flaws in both those legacy protocols as well as the configuration of the devices using them.

TLS 1.3 adds additional advanced security measures to protect against downgrade attacks through the use of special values embedded in the server's random value during the handshake process which help to signal whether or not a client is attempting to force the server into using a lower version of TLS. Modern web browsers and modern servers that are communicating with each other can identify and block suspicious downgrade requests.

It is also strongly recommended that SecureFlow Disable both SSL 3.0, as well as both TLS 1.0 and TLS 1.1 all together, thereby eliminating the ability for legacy protocol risks to occur.

5.1.4 Recommendation

All public-facing applications must adopt a TLS 1.3 (first) policy, and only support TLS 1.2 for compatibility reasons for connecting legacy systems. The advantages of TLS 1.3 include stronger encryption, guaranteed forward secrecy, quicker connections, and better downgrade protection than previous versions; since SecureFlow is a fintech company and processes financial transactions, it will benefit from the increased levels of security and improved performance provided by TLS 1.3.

5.2 Email Security Evaluation: SPF, DKIM and DMARC

5.2.1 Introduction

Cyber criminals frequently target email as an attack vector; phishing, business email compromise (BEC), and e-mail spoofing are some examples of threats that can lead to credential theft, malware infection, or financial fraud. SecureFlow relies extensively upon email communication in both the customer and employee realms and between business partners. Because of this heavy reliance on e-mail as a mode of communication, email security is very important to SecureFlow.

5.2.2 Sender Policy Framework (SPF)

Domain owners can define the specific mail servers that are permitted to deliver e-mail on their behalf by publishing an Sender Policy Framework (SPF) record in the DNS. This published information is stored as a DNS Text record.

Each time an e-mail message is received at a receiving mail server, that mail server will check the record in the DNS and see if the source IP address of the e-mail matches a mail server that is authorized to send for that domain.

SPF does help reduce the ability to spoof e-mail messages directly, but does not perform any verification of the content of the e-mail, and it may not work in cases where e-mail messages are forwarded through an intermediate mail server.

5.2.3 DomainKeys Identified Mail (DKIM)

DomainKey Identified Mail (DKIM) is a cryptographically-based system for verifying the sender's identity (Crocker et al., 2011). DKIM uses a digital signature attached to each email message sent by SecureFlow's mail server. Each DKIM signature is created with a private key on the SecureFlow mail server, while its corresponding public key is placed in DNS. Upon receipt of an email message with a corresponding DKIM signature, the receiving mail server uses the DKIM signature to verify the message was not altered during transmission.

In addition to verifying that messages were not altered during transmission, DKIM also helps confirm that email messages are legitimately associated with SecureFlow's infrastructure.

5.2.4 Domain-based Message Authentication, Reporting and Conformance (DMARC)

DMARC (Domain-based Message Authentication, Reporting, and Conformance) is an authentication framework that adds additional security features to existing authentication frameworks by defining how these other frameworks should be enforced and tracked (Kucherawy & Zwicky, 2015). DMARC policies can be set to three different states of enforcement policies for email messages:

1. "none" (for monitoring only)
2. "quarantine" (to move all suspicious messages to spam)
3. "reject" (to block all suspicious email messages).

Additionally, DMARC also provides reporting capabilities that enable security administrators to determine if they are experiencing spoofing attempts and to measure the performance of their email authentication systems.

5.2.5 How SPF, DKIM and DMARC Work Together

The three technologies complement each other:

Protocol	Primary Function
SPF	Validates authorised sending servers
DKIM	Verifies message integrity and authenticity
DMARC	Enforces policy and reporting using SPF and DKIM results

These mechanisms really help to lower the risk of email spoofing and phishing attacks, on SecureFlow employees and customers. The three technologies complement each other: Together, these mechanisms significantly reduce the risk of email spoofing and phishing attacks targeting SecureFlow employees and customers.

5.2.6 Remaining Limitations

While SPF, DKIM, and DMARC offer good protections against phishing attacks, none of these protocols can fully eliminate phishing threats. Attackers can still do one or more of the following:

- Create look-alike domains (for example: secureflow.com)
- Use real email accounts to conduct social engineering attacks
- Hack into employee accounts and send authenticated malicious emails from these accounts Use third-party delivery services that pass all authentication checks to deliver phishing emails.

As a result, SecureFlow will need to use email-authentication technologies in conjunction with security-awareness training, filtering solutions, and MFA.

5.2.7 Recommendation

The implementation of SPF, DKIM, and DMARC together will allow for the best email security and protection from spoofing for SecureFlow, SPF, DKIM and DMARC should be implemented together and tested before use with a DMARC policy of p=reject to ensure maximum security against spoofing and regulatory compliance as well as customer confidence in the brand.

5.3 IPsec VPN vs TLS VPN Comparison

5.3.1 Introduction

SecureFlow has to maintain a secure connection between the company's HQ and the branch office and allow access for remote employees. Two prevalent forms of virtual private network (VPN) technologies include IPsec VPNs, and TLS-based VPNs; both provide secure communication through the encryption of data transmitting over the Internet, but there are differences between how they are deployed as well as what they are used for.

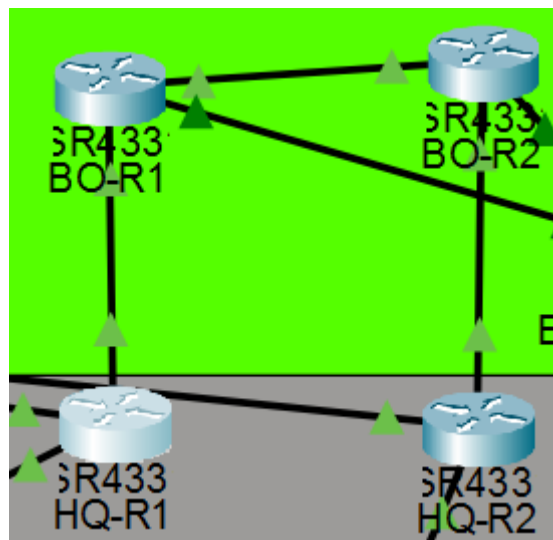


Figure 5.3.1: Site-to-site VPN Architecture

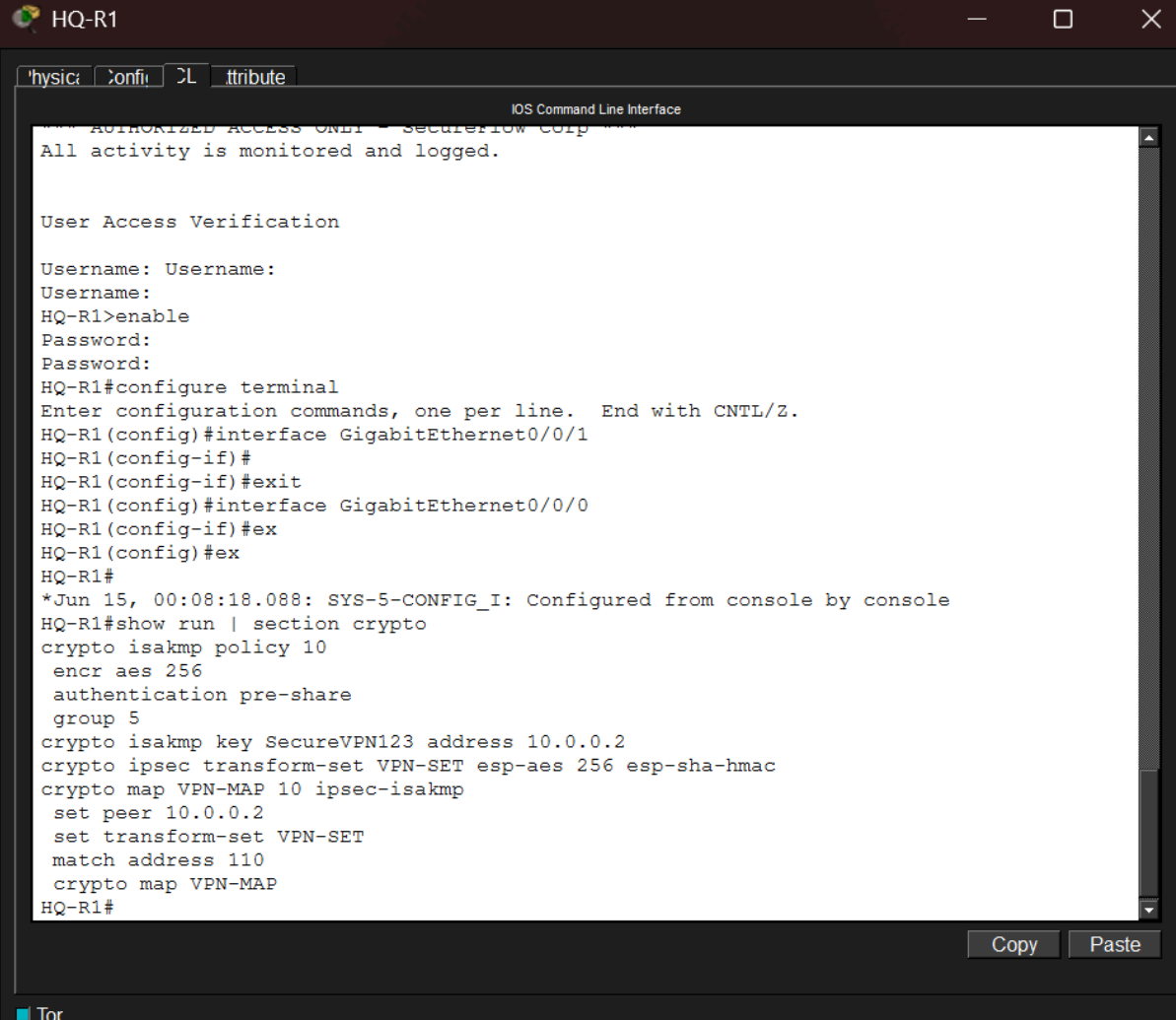
5.3.2 Comparative Analysis

Criteria	IPsec VPN	TLS VPN
OSI Layer	Network Layer (Layer 3)	Application Layer (Layer 7)
Typical Use	Site-to-site VPN	Remote access VPN
Security	Strong encryption and authentication	Strong encryption through TLS
Performance	Lower overhead for network-wide traffic	Slightly higher overhead
Deployment	More complex configuration	Easier deployment
Application Support	All IP traffic	Selected applications and services
Firewall Traversal	Sometimes difficult	Usually easier over HTTPS (Port 443)
Scalability	Excellent	Excellent for remote workers

5.3.3 Suitability for SecureFlow

For the connection between headquarters and branch offices, IPsec VPN is the better choice. The assignment already requires a site-to-site IPsec VPN using AES-256 and SHA-256 because IPsec provides secure transparent connectivity between entire networks. IPsec operates at the Network Layer and protects all IP traffic between endpoints, making it suitable for site-to-site VPN deployments (Kent & Seo, 2005).

For remote employees working from home, TLS VPN solutions are generally more suitable. Since TLS VPN traffic operates over HTTPS, it can pass through most firewalls and NAT devices with fewer connectivity issues. TLS VPNs are commonly used for remote-access scenarios because they leverage HTTPS connectivity and are easier to traverse firewalls (Stallings, 2020).



```
HQ-R1
'physical' 'config' 'show' 'debug'
IOS Command Line Interface
AUTHORIZED ACCESS ONLY - SecureFlow Corp
All activity is monitored and logged.

User Access Verification
Username: Username:
Username:
HQ-R1>enable
Password:
Password:
HQ-R1#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
HQ-R1(config)#interface GigabitEthernet0/0/1
HQ-R1(config-if)#
HQ-R1(config-if)#exit
HQ-R1(config)#interface GigabitEthernet0/0/0
HQ-R1(config-if)#ex
HQ-R1(config)#ex
HQ-R1#
*Jun 15, 00:08:18.088: SYS-5-CONFIG_I: Configured from console by console
HQ-R1#show run | section crypto
crypto isakmp policy 10
  encr aes 256
  authentication pre-share
  group 5
crypto isakmp key SecureVPN123 address 10.0.0.2
crypto ipsec transform-set VPN-SET esp-aes 256 esp-sha-hmac
crypto map VPN-MAP 10 ipsec-isakmp
  set peer 10.0.0.2
  set transform-set VPN-SET
  match address 110
crypto map VPN-MAP
HQ-R1#
```

Figure 5.3.3: IPsec VPN Configuration Evidence

5.3.4 Performance Overhead

IPsec generally offers better performance for continuous site-to-site traffic because encryption occurs at the network layer and protects all traffic automatically.

TLS VPNs may introduce additional processing overhead because encryption occurs at the transport/application layer and often relies on browser or client-based sessions.

5.3.5 Deployment Complexity

IPsec VPN deployment requires configuration of:

- Security Associations (SA)
- IKEv2 negotiation
- Encryption policies
- Authentication mechanisms

TLS VPN deployment is typically simpler because it relies on standard TLS certificates and HTTPS infrastructure.

5.3.6 Security Assurance

When properly configured, both technologies ensure a high level of security. In contrast to IPsec's ability to provide security to all IP traffic coming from the connected networks, TLS VPN's primary focus is on securing application-level access for remote users – this gives IPsec a wider breadth of overall protection than that of the TLS VPN.

```
C:\>ping 10.10.10.122

Pinging 10.10.10.122 with 32 bytes of data:

Reply from 10.10.10.122: bytes=32 time<1ms TTL=124
Reply from 10.10.10.122: bytes=32 time<1ms TTL=124
Reply from 10.10.10.122: bytes=32 time<1ms TTL=124
Reply from 10.10.10.122: bytes=32 time<1ms TTL=124

Ping statistics for 10.10.10.122:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
```

Figure 5.3.6: VPN Connectivity Assurance

5.3.7 Recommendation

A combination of hybrid VPNs is recommended for use by SecureFlow. The hybrid VPN topologies consist of:

- Headquarters to branch connectivity through an IPsec VPN (with IKEv2, AES-256, and SHA-256).
- Access to remote employees is through a TLS VPN.
- To improve user security, MFA should be enforced for all remote users.
- Use certificate base authentication wherever possible.

This strategy provides security, performance, scalability, and operational flexibility to SecureFlow's fintech environment.

6. Consolidate Recommendation

The assessment that has been made during the course of this project indicates that there are many ways in which the security of SecureFlow's network infrastructure can be made stronger. Even though there are already many security features, including VLAN segmentation, firewalls, IPsec VPN tunnels, RADIUS authentication, and IDS, there are more things that can be done to further reduce the amount and type of potential risks to security. The recommendations are going to be given below in order of priority and potential impact.

Timeline	Recommendation	Reason
Immediate (0–30 Days)	Enable TLS 1.3 on all public-facing web servers and gradually discontinue older TLS versions where compatibility allows.	SecureFlow's web servers handle sensitive customer information and financial transactions. Adopting TLS 1.3 provides stronger encryption and better protection against known weaknesses found in older protocols.
Immediate (0–30 Days)	Implement SPF, DKIM and DMARC for the organisation's email domain.	These technologies help verify the legitimacy of emails sent from SecureFlow and can significantly reduce the risk of phishing and email spoofing attacks.
Immediate (0–30 Days)	Review the existing firewall policies on FW1 and FW2 to ensure that only necessary services are exposed to external users.	Reducing unnecessary access points lowers the attack surface and makes it more difficult for attackers to reach internal resources.
Immediate (0–30 Days)	Restrict device administration to SSH and remove any insecure remote management methods.	Using encrypted management sessions helps protect administrator credentials and prevents sensitive information from being exposed during device configuration activities.
Short-Term (1–3 Months)	Enhance monitoring capabilities by fully utilising the IDS systems deployed	Continuous monitoring can help identify suspicious behaviour and provide early

	within the DMZ environment.	warning signs of potential attacks.
Short-Term (1–3 Months)	Strengthen wireless security by enforcing authentication through the existing RADIUS infrastructure.	Centralised authentication improves access control and provides better visibility over users connecting to the network.
Short-Term (1–3 Months)	Conduct cybersecurity awareness sessions for employees.	Technical controls alone are not sufficient, as many attacks still rely on human error and social engineering techniques.
Long-Term (3–12 Months)	Implement Multi-Factor Authentication (MFA) for administrative accounts and remote access services.	MFA provides an additional layer of security and reduces the risk of unauthorised access if passwords are compromised.
Long-Term (3–12 Months)	Deploy a centralised logging and monitoring platform.	Collecting logs from multiple devices in a single location improves visibility and supports faster incident investigation.
Long-Term (3–12 Months)	Conduct periodic vulnerability assessments and penetration testing exercises.	Regular security testing helps identify weaknesses that may not be visible during normal operations and ensures that existing controls remain effective.

6.1 Security Improvement Roadmap

The gradual introduction of new features is designed to lessen the impact on everyday operations and continue to build on SecureFlow's overall security posture. After securing their Internet-facing services (including their emails), the next phase will provide SecureFlow the assurance that all administrative access to their systems is being managed securely according to established best practice.

Once SecureFlow has implemented these initial controls, it can then begin developing its enhanced monitoring capabilities across, and improving upon, the methods used to authenticate users in its network over the longer term.

In time, SecureFlow should establish a more proactive approach to Information Security, (i.e., multiple-factor user authentication methods, centralised monitoring, and regular penetration tests) as these measures will improve not only the organisations' capacity for preventing unauthorised access to its systems, but also its ability to detect and respond to any security incidents that may occur.

By adhering to this roadmap, SecureFlow will continue to enhance its cybersecurity posture and provide reliable and secure services to its customers and employees.

7. Conclusion

With this analysis, in addition to the evaluation of different security protocols such as TLS v1.3, the security position of SecureFlow Sdn Bhd has been assessed through the application of various approaches that will help mitigate the dangers of cyber-attacks or threats that may face the company. As part of this assessment, several risk factors have been identified through the use of the STRIDE threat modelling technique (a technique for assessing threats) in five main areas of the network, which include: internal communications and connectivity, wireless communications and connectivity, publicly available services, email systems, and remote access infrastructure.

To manage these risks, a secure enterprise architecture has been developed and built with the help of Cisco Packet Tracer. This secure enterprise network architecture involves the use of multiple security measures, such as VLAN segmentation, firewalls, site-to-site IPSec VPN connectivity, RADIUS authentication, isolation of the DMZ, IDS devices, and hardening of all devices connected to the network.

Based on the analysis of the used security protocols, it can be concluded that secure communication among employees through advanced technologies such as TLS version 1.3, SPF, DKIM, DMARC, and IPSec VPN would provide SecureFlow with additional confidence in the service delivery process. Lastly, all given recommendations, as well as the coherent roadmap for future improvements, would help SecureFlow develop an organized plan for improving security through the use of available resources and cooperation with the company's priorities.

There should be at least three layers of protection to ensure the security of financial information within companies operating in the fintech sector. As any network cannot be considered absolutely safe, there should be a number of limitations implemented from a technological point of view, and regular reviews should be performed concerning the existing security measures while remembering the existing evolving threats from cybercriminals. In the event that a company chooses this strategy to prevent cyber-attacks, the organization should continue functioning even when facing changing cyber threats. Adequate protection of fintech organizations and their data against such threats presupposes a multi-level strategy for

maintaining security. Moreover, Security Awareness training is an essential element for fintech organizations, along with regular reviews.

8. References

IEEE or APA citation format. Minimum 10 credible references (textbooks, RFCs, vendor documentation, academic journals).

1. Rescorla, E. (2018). The Transport Layer Security (TLS) Protocol Version 1.3 (RFC 8446). Internet Engineering Task Force. <https://doi.org/10.17487/RFC8446>
2. Dierks, T., & Rescorla, E. (2008). The Transport Layer Security (TLS) Protocol Version 1.2 (RFC 5246). Internet Engineering Task Force. <https://doi.org/10.17487/RFC5246>
3. Kitterman, S. (2014). Sender Policy Framework (SPF) for Authorizing Use of Domains in Email, Version 1 (RFC 7208). Internet Engineering Task Force. <https://doi.org/10.17487/RFC7208>
4. Crocker, D., Hansen, T., & Kucherawy, M. (2011). DomainKeys Identified Mail (DKIM) Signatures (RFC 6376). Internet Engineering Task Force. <https://doi.org/10.17487/RFC6376>
5. Kucherawy, M., & Zwicky, E. (2015). Domain-based Message Authentication, Reporting, and Conformance (DMARC) (RFC 7489). Internet Engineering Task Force. <https://doi.org/10.17487/RFC7489>
6. Kent, S., & Seo, K. (2005). Security Architecture for the Internet Protocol (RFC 4301). Internet Engineering Task Force. <https://doi.org/10.17487/RFC4301>
7. Stallings, W. (2020). Cryptography and Network Security: Principles and Practice (8th ed.). Pearson.
8. Chapple, M., & Seidl, D. (2021). CompTIA Security+ Study Guide: Exam SY0-601 (8th ed.). Sybex.
9. National Institute of Standards and Technology. (2024). Cybersecurity Framework (CSF) 2.0. U.S. Department of Commerce. <https://www.nist.gov/cyberframework>
10. National Institute of Standards and Technology. (2020). Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5>
11. Cisco Systems. (2024). Cisco Secure Firewall and VPN Best Practices. Cisco Systems. <https://www.cisco.com>
12. Microsoft. (2024). Email authentication in Microsoft 365: SPF, DKIM, and DMARC. Microsoft Learn. <https://learn.microsoft.com>